



Universidad Tecnológica Nacional
Rectorado

Comité de Seguridad de la Información
Coordinación General

POLÍTICAS DE SEGURIDAD DE LA INFORMACIÓN

PLAN DE DESARROLLO E IMPLEMENTACIÓN

Resolución de Rectorado N° 683/10



Universidad Tecnológica Nacional

Rectorado

Comité de Seguridad de la Información

Coordinación General



Universidad Tecnológica Nacional
Rectorado

Comité de Seguridad de la Información
Coordinación General

ÍNDICE

1. INTRODUCCIÓN

1.1. Marco Institucional

1.2. Antecedentes

2. METODOLOGÍA

2.1. Determinación de objetivos a alcanzar en el período

2.2. Instructivo de Trabajo N0 02/07 GNyPE:

3. POLÍTICAS DE SEGURIDAD DE LA INFORMACIÓN

3.1. Objetivos

3.2. Sanciones Previstas por Incumplimiento

4. ORGANIZACIÓN DE LA SEGURIDAD

4.1. Infraestructura de la Seguridad de la Información

4.1.1. Comité de Seguridad de la Información

4.1.2. Asignación de Responsabilidades en Materia de Seguridad de la Información

4.1.3. Proceso de Autorización para Instalaciones de Procesamiento de Información

4.1.4. Asesoramiento Especializado en Materia de Seguridad de la Información

4.1.5. Cooperación entre Organismos

4.1.6. Revisión Independiente de la Seguridad de la Información

4.2. Seguridad Frente al Acceso por Parte de Terceros

4.2.1. Identificación de Riesgos del Acceso de Terceras Partes

4.2.2. Requerimientos de Seguridad en Contratos o Acuerdos con Terceros

4.3. Tercerización

4.3.1. Requerimientos de Seguridad en Contratos de Tercerización

5. CLASIFICACIÓN Y CONTROL DE ACTIVOS

5.1. Inventario de activos

5.2. Clasificación de la información

5.3. Rotulado de la Información

6. SEGURIDAD DEL PERSONAL

6.1. Seguridad en la Definición de Puestos de Trabajo y la



Comité de Seguridad de la Información

Coordinación General

Asignación de Recursos

- 6.1.1. Incorporación de la Seguridad en los Puestos de Trabajo
- 6.1.2. Control y Política del Personal
- 6.1.3. Compromiso de Confidencialidad
- 6.1.4. Términos y Condiciones de Empleo

6.2. Capacitación del Usuario

- 6.2.1. Formación y Capacitación en Materia de Seguridad de la Información

6.3. Respuesta a Incidentes y Anomalías en Materia de Seguridad

- 6.3.1. Comunicación de Incidentes Relativos a la Seguridad
- 6.3.2. Comunicación de Debilidades en Materia de Seguridad
- 6.3.3. Comunicación de Anomalías del Software
- 6.3.4. Aprendiendo de los Incidentes

7. SEGURIDAD FÍSICA Y AMBIENTAL

- 7.1. Perímetro de Seguridad Física**
- 7.2. Controles de Acceso Físico**
- 7.3. Protección de Oficinas, Recintos e Instalaciones**
- 7.4. Desarrollo de Tareas en Áreas Protegidas**
- 7.5. Aislamiento de las Áreas de Recepción y Distribución**
- 7.6. Ubicación y Protección del Equipamiento y Copias de Seguridad**
- 7.7. Suministros de Energía**
- 7.8. Seguridad del Cableado**
- 7.9. Mantenimiento de Equipos**
- 7.10. Seguridad de los Equipos Fuera de las Instalaciones**
- 7.11. Desafectación o Reutilización Segura de los Equipos.**
- 7.12. Políticas de Escritorios y Pantallas Limpias**
- 7.13. Retiro de los Bienes**

8. GESTIÓN DE COMUNICACIONES Y OPERACIONES

8.1. Procedimientos y Responsabilidades Operativas

- 8.1.1. Documentación de los Procedimientos Operativos
- 8.1.2. Control de Cambios en las Operaciones
- 8.1.3. Procedimientos de Manejo de Incidentes
- 8.1.4. Separación de Funciones
- 8.1.5. Separación entre Instalaciones de Desarrollo e Instalaciones Operativas
- 8.1.6. Gestión de Instalaciones Externas

8.2. Planificación y Aprobación de Sistemas

- 8.2.1. Planificación de la Capacidad
- 8.2.2. Aprobación del Sistema

8.3. Protección Contra Software Malicioso

- 8.3.1. Controles Contra Software Malicioso



Comité de Seguridad de la Información

Coordinación General

8.4. Mantenimiento

- 8.4.1. Resguardo de la Información
- 8.4.2. Registro de Actividades del Personal Operativo
- 8.4.3. Registro de Fallas

8.5. Administración de la Red

- 8.5.1. Controles de Redes

8.6. Administración y Seguridad de los Medios de Almacenamiento

- 8.6.1. Administración de Medios Informáticos Removibles
- 8.6.2. Eliminación de Medios de Información
- 8.6.3. Procedimientos de Manejo de la Información
- 8.6.4. Seguridad de la Documentación del Sistema

8.7. Intercambios de Información y Software

- 8.7.1. Acuerdos de Intercambio de Información y Software
- 8.7.2. Seguridad de los Medios en Tránsito
- 8.7.3. Seguridad del Gobierno Electrónico
- 8.7.4. Seguridad del Correo Electrónico
 - 8.7.4.1. Riesgos de Seguridad
 - 8.7.4.2. Política de Correo Electrónico
- 8.7.5. Seguridad de los Sistemas Electrónicos de Oficina
- 8.7.6. Sistemas de Acceso Público
- 8.7.7. Otras Formas de Intercambio de Información

9. CONTROL DE ACCESOS

9.1. Requerimientos para el Control de Acceso

- 9.1.1. Política de Control de Accesos
- 9.1.2. Reglas de Control de Acceso

9.2. Administración de Accesos de Usuarios

- 9.2.1. Registración de Usuarios
- 9.2.2. Administración de Privilegios
- 9.2.3. Administración de Contraseñas de Usuario
- 9.2.4. Administración de Contraseñas Críticas
- 9.2.5. Revisión de Derechos de Acceso de Usuarios

9.3. Responsabilidades del Usuario

- 9.3.1. Uso de Contraseñas
- 9.3.2. Equipos Desatendidos en Áreas de Usuarios

9.4. Control de Acceso a la Red

- 9.4.1. Política de Utilización de los Servicios de Red
- 9.4.2. Camino Forzado
- 9.4.3. Autenticación de Usuarios para Conexiones Externas
- 9.4.4. Autenticación de Nodos
- 9.4.5. Protección de los Puertos (Ports) de Diagnóstico Remoto
- 9.4.6. Subdivisión de Redes



Comité de Seguridad de la Información

Coordinación General

- 9.4.7. Acceso a Internet
- 9.4.8. Control de Conexión a la Red
- 9.4.9. Control de Ruteo de Red
- 9.4.10. Seguridad de los Servicios de Red

9.5. Control de Acceso al Sistema Operativo

- 9.5.1. Identificación Automática de Terminales
- 9.5.2. Procedimientos de Conexión de Terminales
- 9.5.3. Identificación y Autenticación de los Usuarios
- 9.5.4. Sistema de Administración de Contraseñas
- 9.5.5. Uso de Utilitarios de Sistema
- 9.5.6. Alarmas Silenciosas para la Protección de los Usuarios
- 9.5.7. Desconexión de Terminales por Tiempo Muerto
- 9.5.8. Limitación del Horario de Conexión

9.6. Control de Acceso a las Aplicaciones

- 9.6.1. Restricción del Acceso a la Información
- 9.6.2. Aislamiento de los Sistemas Sensibles

9.7. Monitoreo del Acceso y Uso de los Sistemas

- 9.7.1. Registro de Eventos
- 9.7.2. Monitoreo del Uso de los Sistemas
 - 9.7.2.1. Procedimientos y Áreas de Riesgo
 - 9.7.2.2. Factores de Riesgo
 - 9.7.2.3. Registro y Revisión de Eventos
- 9.7.3. Sincronización de Relojes

9.8. Computación Móvil y Trabajo Remoto

- 9.8.1. Computación Móvil
- 9.8.2. Trabajo Remoto

10. DESARROLLO Y MANTENIMIENTO DE SISTEMAS

10.1. Requerimientos de Seguridad de los Sistemas

- 10.1.1. Análisis y Especificaciones de los Requerimientos de Seguridad

10.2. Seguridad en los Sistemas de Aplicación

- 10.2.1. Validación de Datos de Entrada
- 10.2.2. Controles de Procesamiento Interno
- 10.2.3. Autenticación de Mensajes
- 10.2.4. Validación de Datos de Salidas

10.3. Controles Criptográficos

- 10.3.1. Política de Utilización de Controles Criptográficos
- 10.3.2. Cifrado
- 10.3.3. Firma Digital
- 10.3.4. Servicios de No Repudio
- 10.3.5. Administración de Claves
 - 10.3.5.1. Protección de Claves Criptográficas

10.4. Seguridad de los Archivos del Sistema

- 10.4.1. Control del Software Operativo



Comité de Seguridad de la Información

Coordinación General

- 10.4.2. Protección de los Datos de Prueba del Sistema
- 10.4.3. Control de Cambios a Datos Operativos
- 10.4.4. Control de Acceso a las Bibliotecas de Programas Fuentes

10.5. Seguridad de los Procesos de Desarrollo y Soporte

- 10.5.1. Procedimiento de Control de Cambios
- 10.5.2. Revisión Técnica de los Cambios en el Sistema Operativo
- 10.5.3. Restricción del Cambio de Paquetes de Software
- 10.5.4. Canales Ocultos y Código Malicioso
- 10.5.5. Desarrollo Externo de Software

11. ADMINISTRACIÓN DE LA CONTINUIDAD DE LAS ACTIVIDADES DEL ORGANISMO

11.1. Proceso de la Administración de la Continuidad del Organismo

11.2. Continuidad de las Actividades y Análisis de los Impactos

11.3. Elaboración e Implementación de los Planes de Continuidad de las Actividades del Organismo

11.4. Marco para la Planificación de la Continuidad de las Actividades del Organismo

11.5. Ensayo, Mantenimiento y Reevaluación de los Planes de Continuidad del Organismo

12. CUMPLIMIENTO

12.1. Cumplimiento de Requisitos Legales

- 12.1.1. Identificación de la Legislación Aplicable
- 12.1.2. Derechos de Propiedad Intelectual
 - 12.1.2.1. Derecho de Propiedad Intelectual del Software
- 12.1.3. Protección de los Registros de la Universidad.
- 12.1.4. Protección de Datos y Privacidad de la Información Personal
- 12.1.5. Prevención del Uso Inadecuado de los Recursos de Procesamiento de Información
- 12.1.6. Regulación de Controles para el Uso de Criptografía
- 12.1.7. Recolección de Evidencia

12.2. Revisiones de la Política de Seguridad y la Compatibilidad Técnica

- 12.2.1. Cumplimiento de la Política de Seguridad
- 12.2.2. Verificación de la Compatibilidad Técnica

12.3. Consideraciones de Auditorías de Sistemas

- 12.3.1. Controles de Auditoría de Sistemas
- 12.3.2. Protección de los Elementos Utilizados por la Auditoría de Sistemas

12.4. Sanciones Previstas por Incumplimiento



Universidad Tecnológica Nacional
Rectorado

Comité de Seguridad de la Información

Coordinación General

1. INTRODUCCIÓN

La información es un recurso que, como el resto de los activos, tiene valor para la comunidad universitaria y por consiguiente debe ser debidamente protegida, garantizando la continuidad de los sistemas de información, minimizando los riesgos de daño y contribuyendo de esta manera, a una mejor gestión de la Universidad.

Para que estos principios de la Política de Seguridad de la Información sean efectivos, resulta necesaria la implementación de una Política de Seguridad de la Información que forme parte de la cultura organizacional de la Universidad, lo que implica que debe contarse con el manifiesto compromiso de todos los funcionarios de una manera u otra vinculados a la gestión, para contribuir a la difusión, consolidación y cumplimiento.

Como consecuencia de lo expuesto y con el propósito de que dicha implementación pueda realizarse en forma ordenada y gradual, resulta conveniente la ejecución de un Plan de Acción para el año 2010 que trate los diversos temas del Instructivo de Trabajo N° 02/07 GNYPE.

1.1. Marco institucional

Por Resolución de Rectorado N° 1353/06 el 9 de octubre de 2006, la Universidad Tecnológica Nacional creó el Comité de Seguridad de la Información con los siguientes objetivos:

- 1) Revisar y proponer al Rector de esta Universidad para su consideración y posterior aprobación, las políticas de seguridad de la información y las funciones generales en materia de seguridad de la información que fuera convenientes y apropiadas para esta Universidad.
- 2) Monitorear cambios significativos en los riesgos que afectan a los recursos de la información de esta Universidad frente a posibles amenazas, sean internas o externas.
- 3) Tomar conocimiento y supervisar la investigación y monitoreo de los incidentes, relativos a la seguridad, que se produzcan en el ámbito de esta Universidad.
- 4) Aprobar las principales iniciativas para incrementar la seguridad de la información, de acuerdo a las competencias y responsabilidades asignadas a cada sector, así como acordar y aprobar metodologías y procesos específicos relativos a la seguridad de la información
- 5) Evaluar y coordinar la implementación de controles específicos de seguridad de la información para los sistemas o servicios de esta Universidad, sean preexistente o nuevos.
- 6) Promover la difusión y apoyo a la seguridad de la información dentro de la Universidad, como así, coordinar el proceso de administración de la continuidad de las actividades.



Universidad Tecnológica Nacional
Rectorado

Comité de Seguridad de la Información

Coordinación General

La creación del Comité de Seguridad de la Información se corresponde en un todo con el espíritu y la letra expresados en el Modelo de Política de Seguridad de la Información para Organismos de la Administración Pública Nacional publicado por el ONTI y el Instructivo de Trabajo N° 02/07 GNYPE.

Así mismo, los objetivos del Comité lo convierten en el ámbito propicio para la elaboración de “las políticas de seguridad de la información y las funciones generales en materia de seguridad de la información que fuera convenientes y apropiadas para esta Universidad” (punto 1 de los objetivos establecidos en la Resolución de Rectorado N0 1353/06).

Por Resolución de Rectorado N° 683/10 el 27 de abril de 2010, se aprueban las Políticas de Seguridad de la Información de la Universidad Tecnológica Nacional elaboradas por el Comité de Seguridad de la Información de la Universidad, que fueran elevadas oportunamente al Sr. Rector por la Coordinación General de dicho Comité..

La Resolución de Rectorado N° 683/10 también establece que el Coordinador General del Comité de la Seguridad de la Información deberá elevar a consideración del Rector un Plan de Desarrollo e Implementación de las Políticas de Seguridad de la Información aprobadas.

1.2. Antecedentes

En diciembre de 2006, la Coordinación General del Comité de Seguridad de la Información puso a consideración de los miembros de dicho Comité, una propuesta de las características que debían incluirse en las Políticas de Seguridad de la Información de la Universidad. El texto de la misma es el siguiente:

Objetivos

- * Proteger los recursos de información de la Universidad y la tecnología utilizada para su procesamiento, frente a amenazas, internas o externas, deliberadas o accidentales, con el fin de asegurar el cumplimiento de la confidencialidad, integridad, disponibilidad, legalidad y confiabilidad de la información.
- * Asegurar la implementación de las medidas de seguridad comprendidas en esta Política, identificando los recursos y las partidas presupuestarias correspondientes, sin que ello implique necesariamente la asignación de partidas adicionales.
- * Mantener la Política de Seguridad de la Universidad actualizada, a efectos de asegurar su vigencia y nivel de eficacia.

Alcance

Esta Política se aplica en todo el ámbito de la Universidad, a sus recursos y a la totalidad de los procesos, ya sean internos o externos vinculados a la entidad a través de contratos o acuerdos con terceros. Se conforma de una serie de pautas sobre aspectos específicos de la Seguridad de la Información, que incluyen las siguientes áreas:

1. Organización de la Seguridad

Orientadas a administrar la seguridad de la información dentro de la Universidad y establecer procedi-



Universidad Tecnológica Nacional
Rectorado

Comité de Seguridad de la Información

Coordinación General

mientos de gestión adecuados para controlar su implementación.

Objetivos

Administrar la seguridad de la información dentro de la Universidad y establecer un marco gerencial para iniciar y controlar su implementación, así como para la distribución de funciones y responsabilidades.

Fomentar la consulta y cooperación con Organismos especializados para la obtención de asesoría en materia de seguridad de la información.

Garantizar la aplicación de medidas de seguridad adecuadas en los accesos de terceros a la información de la Universidad.

2. Clasificación y Control de Activos

Destinadas a mantener una adecuada protección de los activos de la Universidad.

Objetivos

Garantizar que los activos de información reciban un apropiado nivel de protección.

Clasificar la información para señalar su sensibilidad y criticidad.

Definir niveles de protección y medidas de tratamiento especial acordes a su clasificación.

3. Seguridad del Personal

Orientadas a reducir los riesgos de error humano, comisión de ilícitos contra la Universidad o uso inadecuado de instalaciones.

Objetivos

Reducir los riesgos de error humano, comisión de ilícitos, uso inadecuado de instalaciones y recursos, y manejo no autorizado de la información.

Explicitar las responsabilidades en materia de seguridad en la etapa de reclutamiento de personal e incluirlas en los acuerdos a firmarse y verificar su cumplimiento durante el desempeño del individuo como empleado.

Garantizar que los usuarios estén al corriente de las amenazas e incumbencias en materia de seguridad de la información, y se encuentren capacitados para respaldar la Política de Seguridad de la Universidad en el transcurso de sus tareas normales.

Establecer Compromisos de Confidencialidad con todo el personal y usuarios externos de las instalaciones de procesamiento de información.

Establecer las herramientas y mecanismos necesarios para promover la comunicación de debilidades existentes en materia de seguridad, así como de los incidentes ocurridos, con el objeto de minimizar sus efectos y prevenir su reincidencia.

4. Seguridad Física y Ambiental

Destinadas a impedir accesos no autorizados, daños e interferencia a las sedes e información de la Universidad.

Objetivos

Prevenir e impedir accesos no autorizados, daños e interferencia a las sedes, instalaciones e



Universidad Tecnológica Nacional
Rectorado

Comité de Seguridad de la Información

Coordinación General

información de la Universidad.

Proteger el equipamiento de procesamiento de información crítica de la Universidad ubicándolo en áreas protegidas y resguardadas por un perímetro de seguridad definido, con medidas de seguridad y controles de acceso apropiados. Asimismo, contemplar la protección del mismo en su traslado y permanencia fuera de las áreas protegidas, por motivos de mantenimiento u otros.

Controlar los factores ambientales que podrían perjudicar el correcto funcionamiento del equipamiento informático que alberga la información de la Universidad.

Implementar medidas para proteger la información manejada por el personal en las oficinas, en el marco normal de sus labores habituales.

Proporcionar protección proporcional a los riesgos identificados.

5. Gestión de las Comunicaciones y las Operaciones

Dirigidas a garantizar el funcionamiento correcto y seguro de las instalaciones de procesamiento de la información y medios de comunicación.

Objetivos

Garantizar el funcionamiento correcto y seguro de las instalaciones de procesamiento de la información y comunicaciones.

Establecer responsabilidades y procedimientos para su gestión y operación, incluyendo instrucciones operativas, procedimientos para la respuesta a incidentes y separación de funciones.

6. Control de Acceso

Orientadas a controlar el acceso lógico a la información.

Objetivos

Impedir el acceso no autorizado a los sistemas de información, bases de datos y servicios de información.

Implementar seguridad en los accesos de usuarios por medio de técnicas de autenticación y autorización.

Controlar la seguridad de la red de la Universidad y de la conexión entre la misma y otras redes públicas o privadas.

Registrar y revisar eventos y actividades críticas llevadas a cabo por los usuarios en los sistemas.

Instalar en los usuarios la importancia de su responsabilidad frente a la utilización de contraseñas y equipos.

Garantizar la seguridad

7. Desarrollo y Mantenimiento de los Sistemas

Orientadas a garantizar la incorporación de medidas de seguridad en los sistemas de información desde su desarrollo y/o implementación y durante su mantenimiento.

Objetivos

Asegurar la inclusión de controles de seguridad y validación de datos en el desarrollo de los sistemas de información.



Universidad Tecnológica Nacional
Rectorado

Comité de Seguridad de la Información

Coordinación General

Definir y documentar las normas y procedimientos que se aplicarán durante el ciclo de vida de los aplicativos y en la infraestructura de base en la cual se apoyan.

Definir los métodos de protección de la información crítica o sensible.

8. Administración de la Continuidad de las Actividades de la Universidad

Orientadas a contrarrestar las interrupciones de las actividades y proteger los procesos críticos de los efectos de fallas significativas o desastres.

Objetivos

Minimizar los efectos de las posibles interrupciones de las actividades normales de la Universidad (sean éstas resultado de desastres naturales, accidentes, fallas en el equipamiento, acciones deliberadas u otros hechos) y proteger los procesos críticos mediante una combinación de controles preventivos y acciones de recuperación.

Analizar las consecuencias de la interrupción del servicio y tomar las medidas correspondientes para la prevención de hechos similares en el futuro.

Maximizar la efectividad de las operaciones de contingencia de la Universidad con el establecimiento de planes que incluyan al menos las siguientes etapas:

Notificación / Activación: Consistente en la detección y determinación del daño y la activación del plan.

Reanudación: Consistente en la restauración temporal de las operaciones y recuperación del daño producido al sistema original.

Recuperación: Consistente en la restauración de las capacidades de proceso del sistema a las condiciones de operación normales.

Asegurar la coordinación con el personal de la Universidad y los contactos externos que participarán en las estrategias de planificación de contingencias. Asignar funciones para cada actividad definida.

9. Cumplimiento

Destinadas a impedir infracciones y violaciones de las leyes del derecho civil y penal; de las obligaciones establecidas por leyes, estatutos, normas, reglamentos o contratos; y de los requisitos de seguridad.

Objetivos

Cumplir con las disposiciones normativas y contractuales a fin de evitar sanciones administrativas a la Universidad y/o al empleado o que incurran en responsabilidad civil o penal como resultado de su incumplimiento.

Garantizar que los sistemas cumplan con la política, normas y procedimientos de seguridad de la Universidad.

Revisar la seguridad de los sistemas de información periódicamente a efectos de garantizar la adecuada aplicación de la política, normas y procedimientos de seguridad, sobre las plataformas tecnológicas y los sistemas de información.

Optimizar la eficacia del proceso de auditoria de sistemas y minimizar los problemas que pudiera



Comité de Seguridad de la Información

Coordinación General

ocasionar el mismo, o los obstáculos que pudieran afectarlo.

Garantizar la existencia de controles que protejan los sistemas en producción y las herramientas de auditoría en el transcurso de las auditorías de sistemas.

Determinar los plazos para el mantenimiento de información y para la recolección de evidencia de la Universidad.

En la reunión del Comité de Seguridad de la Información realizada el 18 de Octubre de 2007, el Coordinador General del Comité pone a consideración dos documentos : Política de Seguridad de la Información, que reitera el contenido del documento presentado en diciembre de 2006 y cuyo contenido se ha transcrita *ut supra*, y Objetivos a Implementar en el Corto Plazo, cuyo contenido se transcribe a continuación. Ambos documentos son aprobados con el voto unánime de los miembros presentes del Comité.

OBJETIVOS A IMPLEMENTAR EN EL CORTO PLAZO

AREA

1. Organización de la Seguridad

Administrar la seguridad de la información dentro de la Universidad y establecer procedimientos de gestión adecuados para controlar su implementación

OBJETIVOS

1.1. Administrar la seguridad de la información dentro de la Universidad y establecer un marco gerencial para iniciar y controlar su implementación, así como para la distribución de funciones y responsabilidades.

AREA

3. Seguridad Física y Ambiental

Impedir accesos no autorizados, daños e interferencia a las sedes e información de la Universidad.

OBJETIVOS

3.1. Prevenir e impedir accesos no autorizados, daños e interferencia a las sedes, instalaciones e información de la Universidad.

AREA

4. Gestión de las Comunicaciones y las Operaciones

Garantizar el funcionamiento correcto y seguro de las instalaciones de procesamiento de la información y medios de comunicación.

OBJETIVOS

4.1. Establecer responsabilidades y procedimientos para su gestión y operación, incluyendo instrucciones operativas, procedimientos para la respuesta a incidentes y separación de funciones.

AREA

5. Control de Acceso



Universidad Tecnológica Nacional
Rectorado

Comité de Seguridad de la Información

Coordinación General

Orientadas a controlar el acceso lógico a la información.

OBJETIVOS

5.1. Controlar la seguridad de la red de la Universidad y de la conexión entre la misma y otras redes públicas o privadas.

5.2. Instalar en los usuarios la importancia de su responsabilidad frente a la utilización de contraseñas y equipos.

AREA

4. Gestión de las Comunicaciones y las Operaciones

Garantizar el funcionamiento correcto y seguro de las instalaciones de procesamiento de la información y medios de comunicación.

OBJETIVOS

4.1. Establecer responsabilidades y procedimientos para su gestión y operación, incluyendo instrucciones operativas, procedimientos para la respuesta a incidentes y separación de funciones.

En esa misma reunión, el Comité toma conocimiento que la Auditoría Interna ha remitido la Metodología Uniforme Para Evaluar las Políticas de Seguridad de la Información, establecidas por la Sindicatura General de la Nación, la que consiste en un cuestionario de 75 páginas y de 978 preguntas distribuidas temáticamente de la siguiente forma:

Política De Seguridad De La Información ... Total 80 Preguntas

Organización De La Seguridad ... Total 24 Preguntas

Clasificación Y Control De Activos ... Total 32 Preguntas

Seguridad Personal ... Total 38 Preguntas

Seguridad Física Y Ambiental ... Total 68 Preguntas

Gestión De Comunicaciones Y Operaciones ... Total 228 Preguntas

Control De Accesos ...Total 258 Preguntas

Desarrollo Y Mantenimiento De Sistemas ... Total 88 Preguntas

Administración De La Continuidad De Las Actividades Del Organismo ... Total 67 Preguntas

Cumplimiento ... Total 95 Preguntas

En enero de 2009, la Unidad de Auditoría Interna de la SIGEN presenta un informe donde expresa que “la Universidad Tecnológica Nacional carece de una Política de Seguridad de la Información escrita e implementada” y plantea “dar implementación, el Comité de Seguridad de la Información, un Plan de Acción donde se traten los diversos temas del Instructivo de Trabajo N0 02/07 GNyPE y a fin de otorgar medidas correctiva, si así lo ameritara, todo ello con el objeto de que la Universidad cuente con una política de seguridad de información a



Comité de Seguridad de la Información

Coordinación General

efecto de elevar los niveles de seguridad de sus sistemas de información. El mencionado Plan de Acción deberá de estipularse el plazo en que se estima que se implementara una medida correctiva, si hiciere falta, para cada uno de los puntos del Instructivo”, y que “asimismo, la Universidad deberá diseñar e implementar una política de seguridad de la información tomando en consideración el Modelo aprobado por la Decisión Administrativa N° 6/2005 de la Oficina Nacional de Tecnologías de la Información”.

En enero de 2010, la Unidad de Auditoría Interna de la SIGEN presenta un informe donde expresa que:

“1. Las Políticas de Seguridad de la Información elaborada por la Coordinación General no se encuentra formalmente aprobada por la máxima autoridad, incumpléndose el artículo 4° inciso 1 de la Disposición Administrativa N° 669/2004.

2. Respecto a la implementación de las Políticas de Seguridad de la Información de la Universidad, no se encuentran implementadas.

La ausencia de implementación podría genera: menor reacción a incidentes de seguridad, planeamiento y manejo de la seguridad pocos efectivos, la no cuantificación de los posibles daños por ataques a la seguridad de la información, duplicación de tareas y dificultad en el intercambio de información, desconfianza de terceros, menor control de la información proporcionada a terceros, etc.”

y recomienda:

“1. Elevar para su aprobación ante la máxima autoridad de esta Casa de Altos Estudios las Políticas de Seguridad de la Información, elaborada por la Coordinación General del Comité de Seguridad de la Información.

2. Dar desarrollo e implementación de las Políticas de Seguridad de la Información las que deben de tratarse como un proyecto más de la Universidad, involucrando una planificación, una asignación de recursos y un control y seguimiento de su curso. Debiéndose involucrar al personal de diferentes áreas del Organismo, y su prioridad debe ser alta en relación a las actividades diarias desempeñadas por el personal asignado.”

La Resolución de Rectorado N° 683/10 cumplimenta la primera de las recomendaciones, mientras que el presente Plan de Desarrollo e Implementación de las Políticas de Seguridad de la Información plantea dar respuesta a la segunda recomendación de la Unidad de Auditoría Interna de la SIGEN, cumplimentando lo requerido en Artículo 2° de la Resolución de Rectorado N° 683/10.

Conjuntamente con las Políticas de Seguridad de la Información de la Universidad, constituyen un abordaje del tema desde la doble perspectiva del marco general que se describe en las políticas, con objetivos específicos en los diversos temas vinculados, en un todo



Universidad Tecnológica Nacional
Rectorado

Comité de Seguridad de la Información
Coordinación General

de acuerdo con el Modelo aprobado por la Decisión Administrativa N0 6/2005 de la Oficina Nacional de Tecnologías de la Información.



Universidad Tecnológica Nacional
Rectorado

Comité de Seguridad de la Información
Coordinación General

2. METODOLOGÍA

2.1. Determinación de objetivos a alcanzar en el período

De la lectura del Instructivo de Trabajo N0 02/07 GNyPE se desprende un ordenamiento de temas y cuestiones vinculados a la Seguridad de la Información que serán tenidos en cuenta para la determinación de cada uno de los objetivos a alcanzar en el período.

El Comité de Seguridad de la Información elevará a consideración del Señor Rector, los objetivos que vaya determinando, describiéndolos a través de los siguientes parámetros:

- a) Denominación
- b) Descripción
- c) Alcances
- d) Formas de realización
- e) Recursos afectados
- f) Fecha de cumplimiento

2.2. Instructivo de Trabajo N0 02/07 GNyPE

Se transcriben a continuación, las preguntas incorporadas al Instructivo de Trabajo N0 02/07 GNyPE



Comité de Seguridad de la Información
Coordinación General

3.1. POLÍTICA DE SEGURIDAD DE LA INFORMACIÓN

¿Cuenta el organismo con una Política de Seguridad de la Información formalmente establecida, aprobada y publicada?

¿Establece la Política, en forma clara y sencilla, sus objetivos y alcances generales?

¿Incluye mínimamente los tópicos de organización de la seguridad, clasificación y control de activos, seguridad del personal, seguridad física y ambiental, gestión de comunicaciones y las operaciones, control de acceso, desarrollo y mantenimiento de los sistemas, administración de la continuidad de las actividades cumplimiento, entre otros?

Al ser la información un activo para la organización ¿están definidos los recursos de información que deben ser protegidos?

¿Incluye un esquema de clasificación que preserve los criterios de confidencialidad, integridad, disponibilidad, legalidad y confiabilidad?

La Política de Seguridad de la Información implementada ¿incluye normas y/o procedimientos para garantizar la continuidad de los sistemas de información, minimizando los riesgos de daño y asegurando el eficiente cumplimiento de los objetivos del organismo?

¿Está sustentada la Política por una evaluación de riesgos?

¿Es la Política concordante con los objetivos del organismo?

¿Contempla la Política las disposiciones legales vigentes?

¿Define las responsabilidades de las personas, departamentos y organizaciones para los que aplica la política de seguridad?

¿Define los roles objetivos para cada nivel de responsabilidad?

¿Define las sanciones en caso de incumplimiento?

¿Establece el resguardo adecuado de la información documentada?

¿Establece la existencia de controles de acceso a la información? ¿Establece la existencia de procedimientos de copias de seguridad de la información?

¿Se lleva a cabo la asignación de responsabilidades de la seguridad informática?



Universidad Tecnológica Nacional
Rectorado

Comité de Seguridad de la Información
Coordinación General

¿Establece su ámbito de aplicación a todo el organismo?
¿Resguarda todos los procesos vinculados al organismo?
¿Se encuentran las máximas autoridades formalmente comprometidas con la seguridad de la información?
En la elaboración de la Política ¿se tuvo en Cuenta la totalidad de los procesos de gestión llevados a cabo en el organismo? ¿Existen mecanismos formalmente establecidos que permitan verificar el cumplimiento de la Política de Seguridad de la Información? ¿Se encuentra el personal del organismo comprometido formalmente con la Seguridad de la información?
¿Es conocida por la totalidad de la planta del organismo sea cual fuere su nivel jerárquico e incluyendo a funcionarios políticos?
El personal del organismo ¿ha sido concientizado de la importancia de contar con dichas políticas?
¿Celebra el organismo contratos de confidencialidad de la información con los encargados de administrar y resguardar la información del organismo?
¿Se ha establecido formalmente que todos los Directores Nacionales o organizativas, sea cual fuere su nivel jerárquico, son responsables de la implementación de esta Política de Seguridad de la Información?
¿Define la Política sanciones ante casos de incumplimientos?
Para la aplicación de la Política y las medidas de seguridad ¿se identifican los recursos existentes o disponibles?
¿Se determinan los recursos necesarios?
¿Se determinan las partidas presupuestarias con relación a la Política de seguridad adoptada y los recursos disponibles y necesarios?



Universidad Tecnológica Nacional
Rectorado

Comité de Seguridad de la Información
Coordinación General

3.2. COMITÉ DE SEGURIDAD DE LA INFORMACIÓN	
¿Cuenta el organismo con un Comité De Seguridad de la Información?	
¿Existe una norma en el organismo que determine formalmente las pautas de funcionamiento del Comité?	
¿Se encuentra definido qué personal integrará el Comité de Seguridad?	
¿Se establecieron formalmente sus deberes responsabilidades?	
¿Se realiza un control que permita detectar cambios significativos en los riesgos que quedan afectar los recursos de información?	
¿Se realiza la investigación y el monitoreo de los incidentes relativos a la Seguridad?	
¿Participa el Comité en la evaluación y coordinación de la implementación de controles específicos de seguridad de la información para nuevos sistemas o servicios?	
¿Participa el Comité en la difusión y apoyo a la seguridad de la información del organismo?	
¿Existen informes de gestión que permitan evaluar el accionan del Comité?	
¿Garantiza el Comité que la Seguridad de la Información sea parte del proceso de planificación de la organización?	
¿Establece formalmente la Política de Seguridad un Coordinador para el Comité de Seguridad de la Información?	
¿Se encuentran definidas las funciones y responsabilidades del Coordinador del Comité de Seguridad de la Información?	
¿Ha designado el organismo un Responsable de la Seguridad Informática?	



Comité de Seguridad de la Información
Coordinación General

3.3. RESPONSABLE DE LA SEGURIDAD INFORMATICA
¿Se ha asignado formalmente al Responsable de la Seguridad Informática la supervisión del cumplimiento de la Política de Seguridad de la Información?
¿Participa el Responsable de Seguridad Informática en la orientación y asesoramiento a las dependencias del organismo respecto de la implementación de la Política?
¿Verifica que la utilización de los recursos de la tecnología de la información contemple los requerimientos de seguridad establecidos según la criticidad de la información que procesan?
¿Implementó el organismo una norma que contemple los distintos niveles de criticidad de la información?
¿Se han incluido en los distintos circuitos administrativos acciones destinadas a brindar seguridad en el manejo de la información?
¿Se encuentra la información debidamente documentada, actualizada y protegida?
¿Existe un adecuado almacenamiento de la información de acuerdo con el nivel de criticidad?
¿Existen copias de Seguridad de la información?
¿Existe algún procedimiento formalmente establecido para la realización y mantenimiento de las copias de seguridad de la información del organismo?
¿Se designó formalmente al responsable de la realización de las copias de seguridad?
¿Se encuentran las copias de seguridad y las claves de acceso debidamente protegidas ante casos de contingencia?
¿Existen permisos de acceso para la información de acuerdo con las funciones y competencias?



Universidad Tecnológica Nacional
Rectorado

Comité de Seguridad de la Información
Coordinación General

3.4. AREA DE RECURSOS HUMANOS	
¿Notifica formalmente el Área de Recursos Humanos al personal que ingresa al organismo sus obligaciones respecto del cumplimiento de la Política de Seguridad de la Información, así como de toda norma, procedimientos y prácticas que de ella surjan?	
¿Notifica formalmente a todo el personal los cambios que se producen en la Política?	
¿Protocoliza la firma de compromisos de confidencialidad?	
¿Realiza las gestiones necesarias para que se brinde al personal capacitación continua en materia de seguridad?	



Universidad Tecnológica Nacional
Rectorado

Comité de Seguridad de la Información
Coordinación General

3.5. RESPONSABLE DEL ÁREA INFORMÁTICA	
¿Cumple el Área de Sistemas con los requerimientos de Seguridad Informática?	
¿Cumplen los sistemas informáticos con la Política de Seguridad y la legislación vigente?	
¿Poseen los sistemas informáticos medidas de Seguridad razonables?	
¿Existen políticas y procedimientos referentes a recuperación de información y continuidad de operaciones ante la ocurrencia de contingencias?	
¿Existen políticas y procedimientos para el desarrollo, adquisición y mantenimiento de software utilizado por el organismo, siguiendo una metodología de ciclo de vida de sistemas?	
¿Existe una adecuada segregación de funciones dentro del área de sistemas?	
¿Cuenta el centro de cómputos con sistemas de control de acceso físico a sus instalaciones?	
¿Cumple el personal del Área de Sistemas con el perfil adecuado para el cargo que desempeña?	
¿Existe una adecuada distribución de funciones y responsabilidades en el diseño de la estructura del centro de cómputos, a fin de asegurar el control cruzado del trabajo efectuado, tendiendo a la división de las siguientes funciones a) Control b) Operador?	



Universidad Tecnológica Nacional
Rectorado

Comité de Seguridad de la Información
Coordinación General

3.6. RESPONSABLE DEL ÁREA LEGAL	
¿Se encuentra definida en la Política de Seguridad la participación del funcionario a cargo del Área Legal?	
¿Se verifica el cumplimiento de la presente Política en la gestión de todos los contratos, acuerdos u otra documentación del organismo con sus empleados y terceros?	
¿Se asesora en materia legal al organismo en lo referente a la Seguridad de la Información?	
¿Se actualiza la Política a efectos de garantizar su vigencia y nivel de eficacia?	
¿Verifica el funcionario a cargo del Área Legal que existan sanciones ante incumplimientos de orden legal?	



Comité de Seguridad de la Información
Coordinación General

4.1. ORGANIZACIÓN DE LA SEGURIDAD DE LA INFORMACIÓN
¿Se encuentra conformado el Comité de Seguridad de la Información?
¿Se ha designado un coordinador?
¿Existe un Responsable de Seguridad Informática designado por la máxima autoridad de la organización?
¿Participan los responsables de las unidades organizativas, la Unidad de Auditoría Interna y los responsables del Área de Administración?
¿Tiene asignadas las funciones acorde al modelo de políticas de seguridad de los sistemas de información?
¿Existe una comunicación fluida entre sus integrantes? ¿Queda constancia de dicha comunicación?
¿Se encuentran definidos correctamente los procesos de seguridad de la información?
¿Se designó a los responsables de cada uno de los procesos de seguridad?
¿Se designó a los propietarios de la información?
¿Se encuentran documentadas las responsabilidades que le corresponden a cada funcionario designado?
¿Existen procedimientos de autorización para Instalaciones de Procesamiento de Información?
¿Se encuentran los recursos de procesamiento debidamente autorizados?
¿Se garantiza su compatibilidad con los componentes de otros sistemas del organismo?
¿Está previsto el asesoramiento periódico especializado en materia de seguridad de la información?
¿Se celebran reuniones con otros organismos a fin de mantener una cooperación mutua en la materia?
¿Realiza la Unidad de Auditoría Interna revisiones sobre la vigencia e implementación de la Política de Seguridad de la Información?
¿Existe un responsable para realizar revisiones independientes? ¿Posee la suficiente independencia, capacidad y objetividad en la materia?
¿Se ha realizado y documentado una evaluación de riesgo de la información del organismo?
¿Se encuentran identificados los terceros que acceden a la información?
¿Se formalizaron controles a terceros para el acceso a la información?
¿Se los notificó de la Política de Seguridad del organismo?
¿Se revisaron los contratos o acuerdos existentes con terceros, a fin de incorporar los requerimientos de seguridad incluidos en la Política?



Comité de Seguridad de la Información
Coordinación General

5.1. CLASIFICACIÓN Y CONTROL DE ACTIVOS
¿Se encuentran completamente identificados y clasificados los activos importantes asociados a cada sistema de información en función de la administración de riesgos potenciales?
¿Están identificados sus respectivos propietarios? ¿Se encuentra identificada la ubicación del activo?
Los propietarios de la información ¿han clasificado la información de acuerdo con el grado de sensibilidad y criticidad?
¿Se definieron las funciones que requieren permisos de acceso a la información?
¿Se asegura que la utilización de los recursos de la tecnología de información contempla los requerimientos de seguridad establecidos según su criticidad?
¿Se encarga el Responsable de Seguridad Informática de esa tarea?
¿Se elaboró un inventario con la información recabada sobre activos importantes? ¿Está actualizado?
¿Con que periodicidad se lo revisa? La misma ¿es inferior a seis (6) meses?
¿Se comunicó a todo el personal del organismo sobre la clasificación y control de activos?
¿Se capacitó al personal sobre la clasificación y control de activos?
¿Se prevé un plan de capacitación? ¿Se designó a su titular?
En la clasificación de los activos de información ¿se evalúan las tres (3) características sobre las que se basa la seguridad: confidencialidad, integridad y disponibilidad?
Con relación a la confidencialidad ¿de qué manera se clasifica a la información?
Con relación a la integridad, ¿se halla la información clasificada en los niveles 0,1, 2 y 3? Siendo 0 - Información cuya modificación no autorizada puede repararse fácilmente, o no afecta la operatoria del organismo; 1 -Información cuya modificación no autorizada puede repararse aunque podría ocasionar pérdidas leves para el organismo, el sector público o terceros; 2 -Información cuya modificación no autorizada es de difícil reparación y podría ocasionar pérdidas significativas para el organismo, el sector público o terceros; 3 - Información cuya modificación no autorizada no podría repararse, ocasionando pérdidas graves al organismo, el sector público o a terceros.



Comité de Seguridad de la Información
Coordinación General

Con relación a la disponibilidad ¿se halla la información clasificada en niveles 0,1, 2 y 3 según las pérdidas significativas que puede ocasionar su inaccesibilidad? Siendo 0 - Información cuya inaccesibilidad no afecta la operatoria del organismo; 1 - Información cuya inaccesibilidad permanente durante (definir un plazo no menor a una semana) podría ocasionar pérdidas significativas para el organismo; 2- Información cuya inaccesibilidad permanente durante (definir un plazo no menor a un día) podría ocasionar pérdidas significativas al organismo; 3- Información cuya inaccesibilidad permanente durante (definir un plazo no menor a una hora) podría ocasionar pérdidas significativas al organismo.
¿Recabando la información de clasificación se llega al estado de criticidad general de la información?
¿Se determina la obsolescencia de la información? Detallar en qué forma.
¿Existe un procedimiento formal de destrucción de la información obsoleta que garantice la confidencialidad de la misma hasta el momento de su eliminación?
En relación con las pérdidas del organismo ¿se contemplan en la clasificación tanto las mensurables como las no mensurables?
¿Se realiza periódicamente un mantenimiento preventivo y prueba de los dispositivos de seguridad para la prevención, detección y extinción del fuego?
¿Se asigna a la información un valor por cada uno de los criterios mensurables no mensurables?
¿Se clasifica la información en las categorías de criticidad baja, criticidad media criticidad alta?
El responsable de asignar o cambiar el nivel de clasificación, ¿es el propietario de la información?
¿Se asigna para ello una fecha para la ejecución del cambio? ¿Se comunica la necesidad del cambio y la fecha de ejecución al administrador del recurso?
Al realizar los cambios necesarios ¿se comunica a los usuarios la nueva clasificación?
Luego de clasificada la información, el propietario de la misma ¿identifica los recursos asociados y los perfiles funcionales que deben tener acceso a la misma?
¿Se definieron procedimientos para el rotulado y manejo de información, según el esquema de clasificación definido?
Dichos procedimientos ¿contemplan los recursos de información en formatos físicos y electrónicos?
Con relación a las actividades de procesamiento de la información ¿se realizan copias?
¿Está contemplado en el proceso de almacenamiento, el proceso de rotulado estipulado?
¿Se realizan transmisiones por correo, fax y correo electrónico u otro medio? ¿Se indica en los mismos el carácter reservado de la información enviada?



Universidad Tecnológica Nacional
Rectorado

Comité de Seguridad de la Información
Coordinación General

¿Se indica para las actividades de transmisión oral, de telefonía fija y móvil, correo de voz, contestadores automáticos y otros el carácter de la información? ¿Se destaca cuál es la información que puede ser transmitida?



Universidad Tecnológica Nacional
Rectorado

Comité de Seguridad de la Información Coordinación General

6.1. SEGURIDAD DEL PERSONAL
¿Existe una política de seguridad en la definición de puestos de trabajo y la asignación de recursos?
¿Están incorporadas en la descripción de las responsabilidades de los puestos de trabajo, las funciones y responsabilidades en materia de Seguridad?
¿Se llevan a cabo controles de verificación del personal en el momento en que se solicita el puesto?
Quienes se incorporan a la organización ¿firman un acuerdo de confidencialidad o de no divulgación, respecto del tratamiento de la información del organismo?
¿Es retenida por el Área de Recursos Humanos otra área competente, en forma segura la copia del acuerdo de confidencialidad suscripto por el personal, cualquiera sea su situación de revista?
¿Se comunican en forma detallada al empleado las actividades que van a ser monitoreadas por el acuerdo?
¿Se planifica la revisión del contenido del acuerdo de confidencialidad o de no divulgación a un plazo inferior a un año?
¿Existe un método de nueva suscripción en caso de modificación del texto del acuerdo?
¿Se determinó la responsabilidad del empleado en materia de seguridad de la información, en los términos y condiciones del empleo?
¿Se encuentran aclarados en los términos y condiciones de empleo, los derechos y obligaciones del empleado relativos a la seguridad de la información?
¿Existen casos en los que las responsabilidades exceden la competencia del organismo el horario normal de trabajo?
¿Reciben los empleados del organismo una adecuada capacitación y actualización periódica en materia de la política, normas y procedimientos del organismo?
¿Se los capacita respecto al uso correcto de las instalaciones de procesamiento de información?
¿Quién coordina las acciones de capacitación?
¿Con qué periodicidad se revisa el material disponible para la capacitación a fin de evaluar la pertinencia de su actualización?
La Política de Seguridad ¿establece su aplicación en todo el ámbito del organismo?
¿Están definidas las áreas responsables de producir el material de capacitación?
¿Recibe el personal ingresante, el material de capacitación con suficiente antelación a la asignación de los privilegios de acceso a los sistema que corresponden?



Universidad Tecnológica Nacional
Rectorado

Comité de Seguridad de la Información
Coordinación General

¿De qué forma se comunican las eventuales modificaciones y/o novedades en materia de Seguridad?
¿Existen respuestas frente a incidentes o anomalías en materia de Seguridad?
¿Se comunican, tan pronto como sea posible a los canales gerenciales, los incidentes relativos a la Seguridad?
¿Existe un canal de comunicación formalmente establecido para informar y dar respuesta a incidentes indicando la acción que ha de emprenderse?
¿Se ha informado siempre en forma inmediata al Responsable de Seguridad Informática ante la detección de un supuesto incidente?
¿Qué medidas adopta el Responsable de Seguridad Informática ante una emergencia?
¿Conocen todos los empleados y contratistas el procedimiento de comunicación de incidentes de Seguridad?
¿Informan al Responsable de Seguridad Informática los usuarios de servicios de información, al tomar conocimiento de alguna deficiencia en la Seguridad?
¿Se permite a los usuarios la realización de pruebas para detectar y/o utilizar una supuesta debilidad o falla de Seguridad?
¿Existen procedimientos para comunicar anomalías de software?
¿Se registran los síntomas del problema y los mensajes que aparecen en pantalla?
¿Se ejecutan medidas de aplicación inmediata ante la presencia de una anomalía?
¿Se alerta al Responsable de Seguridad Informática?
¿Pueden los usuarios quitar el software que presenta una anomalía?
¿Se cuenta con un proceso que documente, cuantifique y monitoree los tipos, volúmenes y costos de los incidentes y anomalías?
¿Se detectan aquellos recurrentes o de alto impacto?
¿Se mejoraron o agregaron controles para limitar la frecuencia, daño y costo de casos futuros?
¿Cuál es la actitud que se adopta con aquellos empleados que violan la política, normas y procedimientos de Seguridad?
¿Existen procesos disciplinarios contemplados en normas estatutarias o escalafonarias que rigen al personal de la Administración Pública Nacional?



Comité de Seguridad de la Información
Coordinación General

7.1. POLÍTICA FÍSICA Y AMBIENTAL
Las instalaciones donde se realiza el procesamiento de información crítica o sensible, ¿se encuentran ubicadas dentro del perímetro de un área protegida en el edificio?
¿Es la construcción del área físicamente sólida? ¿Están todas las aberturas que comunican las instalaciones de procesamiento de información con el exterior adecuadamente protegidas contra accesos no autorizados, por ejemplo mediante mecanismos de control?
¿Existe un área de recepción atendida por personal?
Para la selección y el diseño de las áreas protegidas, ¿se tuvieron en cuenta las posibilidades de daños producidos por incendio, inundación, explosión, tumulto, y otras formas de desastres naturales o provocados por el hombre?
¿Se encuentran protegidos adecuadamente todos los equipos tecnológicos o dispositivos auxiliares de soporte sensitivos, como cableado, equipos generadores, dispositivos de red, almacenamiento de resguardos?
¿Se lleva un registro actualizado de los sitios protegidos, indicando área, elementos a proteger y medidas implementadas?
¿Se documentan adecuadamente todos los dispositivos de las instalaciones de procesamiento, los circuitos eléctricos, cableado telefónico, repuestos y elementos de reparación, dispositivos de seguridad como detectores de humo, etc.?
¿Se tomaron en Cuenta las disposiciones y normas (estándares) en materia de sanidad y seguridad? Enunciar principales normas.
¿Se consideraron otras amenazas a la seguridad que pudieran representar los edificios y zonas aledañas (por ejemplo, filtración de agua desde otras instalaciones)?
¿Se ubicaron las instalaciones críticas en lugares discretos a los cuales no pueda acceder el público?
¿Se encuentran separadas las instalaciones de procesamiento de información administradas por el organismo, de aquellas administradas por terceros?
¿Se han identificado y documentado las amenazas potenciales, por ej., por robo o hurto, incendio, humo, inundaciones o filtraciones de agua (o falta de suministro), polvo, vibraciones, etc.? ¿Se han adoptado controles para minimizar cada una de ellas?
El acceso físico a las instalaciones donde se encuentra el equipamiento informático sensible, ¿está restringido sólo a los agentes que lo requieran para llevar a cabo sus tareas? ¿Fueron formalmente autorizados? ¿Se utilizan controles de autenticación para autorizar y validar todos los accesos (por ejemplo personal de guardia con listado de personas habilitadas o por tarjeta magnética o inteligente y número de identificación personal PIN , etc.?



Universidad Tecnológica Nacional
Rectorado

Comité de Seguridad de la Información
Coordinación General

¿Se mantiene un registro protegido de cada ingreso y egreso para permitir auditar todos los accesos?
¿Existe un procedimiento definido para el acceso de visitas a las instalaciones del procesamiento de datos? ¿Se acompaña a las personas ajenas al sector? ¿Se registra la fecha y horario de su ingreso y egreso, detallando propósitos específicos?
¿Se utiliza una identificación unívoca visible para todo el personal del área rote ida?
¿Se revisan y actualizan periódicamente los derechos de acceso a las áreas rote idas?
¿Se restringe el ingreso de equipos de computación móvil, fotográficos, de vídeo, audio o cualquier otro tipo de equipamiento que registre información, a menos que el Responsable de Seguridad Informática, lo autorice formalmente?
¿Está identificado todo el equipamiento informático con etiquetas de inventario? ¿Existe un inventario confiable?
¿Se han implementado medidas de seguridad para la prevención, detección y supresión de incendios en las instalaciones de procesamiento y en toda otra instalación que cuente con recursos informáticos, como por ejemplo cableado, UPS, caja de electricidad, etc.?
¿Se realiza periódicamente un mantenimiento preventivo y prueba de los dispositivos de seguridad para la prevención, detección y extinción del fuego?
Los materiales peligrosos o combustibles ¿se almacenan en lugares seguros a una distancia prudencial de las áreas protegidas del organismo?
¿Se encuentran identificadas claramente todas las puertas de incendio?
Los equipos redundantes y la información de resguardo (back up), ¿se almacenan en un sitio seguro y distante del lugar de procesamiento, a fin de evitar daños ante eventuales contingencias en el sitio principal?
El sector donde se encuentra el equipamiento utilizado para el procesamiento de datos ¿Cuenta con adecuadas condiciones ambientales, temperatura, ventilación, agua potable, etc.?
¿Se prohíbe comer, beber y fumar dentro de las instalaciones de procesamiento de la información?
El suministro de energía ¿está de acuerdo con las especificaciones del fabricante o proveedor de los equipos?
¿Se dispone de múltiples enchufes o líneas de suministro con el objeto de evitar un único punto de falla en el suministro de energía?



Comité de Seguridad de la Información
Coordinación General

¿Se realizó un análisis de impacto de las posibles consecuencias ante una interrupción prolongada del procesamiento, a fin de definir qué componentes será necesario abastecer de energía alternativa? Identificar.
¿Se dispone de suministro de energía ininterrumpible (UPS) para asegurar el apagado regulado y sistemático o la ejecución continua del equipamiento que sustenta las operaciones críticas del organismo?
Los planes de contingencia ¿contemplan las acciones que han de emprenderse ante una falla de la UPS?
Los equipos de UPS ¿se inspeccionan y prueban periódicamente para asegurar si funcionan correctamente y si soportan la carga requerida durante un tiempo preestablecido?
Los planes de contingencia ¿contemplan las acciones que han de emprenderse ante una falla de la UPS?
Los generadores ¿son probados periódicamente de acuerdo con las instrucciones del fabricante o proveedor?
¿Se dispone de un adecuado suministro de combustible para garantizar que el generador pueda funcionar por un período prolongado?
Los interruptores de emergencia ¿se encuentran ubicados cerca de las salidas de emergencia de las salas donde se encuentra el equipamiento, fin de facilitar un corte rápido de la energía en caso de producirse una situación crítica?
¿Se dispone de iluminación de emergencia para eventuales fallas en el suministro principal de energía?
¿Se ha implementado protección contra rayos en todos los edificios y se adaptaron filtros de protección contra rayos en todas las líneas de comunicaciones externas?
¿Se encuentra protegido el cableado de energía eléctrica y de comunicaciones que transporta datos o brinda apoyo a los servicios de información?
El cableado de energía eléctrica y de comunicaciones que transporta datos o brinda apoyo a los servicios de información ¿cumple con los requisitos técnicos vigentes en la República Argentina? (especificar normas).
¿Se utiliza pisoducto o cableado embutido en la pared?
¿Se adoptaron medidas de protección para cableado de red contra interceptación no autorizada o daño?



Comité de Seguridad de la Información
Coordinación General

Los cables de energía de los cables de comunicaciones ¿se encuentran separados por conductos para evitar interferencias?
El tendido del cableado troncal (<i>backbone</i>) ¿se encuentra protegido mediante la utilización de ductos blindados?
¿Se instalaron recintos o cajas con cerraduras en los puntos terminales y de inspección?
¿Se utilizan rutas o medios de transmisión alternativos?
¿Se somete el equipamiento a tareas periódicas de mantenimiento preventivo?
El Área de Informática ¿mantiene un listado actualizado del equipamiento con el detalle de la frecuencia en que se realiza el mantenimiento preventivo?
¿Se ha establecido que sólo el personal de mantenimiento autorizado puede brindar mantenimiento y llevar a cabo reparaciones en el equipamiento?
¿Se registran todas las fallas supuestas o reales y todo el mantenimiento preventivo correctivo realizado?
¿Se definió un procedimiento para el ingreso y egreso de equipos o dispositivos informáticos a la sala de procesamiento del organismo? ¿Se requiere la autorización del responsable de la unidad?
¿Existe un procedimiento para eliminar la información confidencial que contenga cualquier equipo que sea necesario retirar del organismo, realizándose previamente las respectivas copias de resguardo?
¿Existen controles para asegurar que el equipamiento destinado al procesamiento de información fuera del ámbito del organismo, será autorizado por el propietario de la información almacenada en el mismo?
¿Se comprobó que la seguridad provista sea equivalente a la suministrada dentro del ámbito del organismo?
¿Se respetan las instrucciones del fabricante respecto del cuidado del equipamiento?
¿Se cuenta con un seguro para el equipamiento fuera del ámbito del organismo?
Al momento de desafectar o reutilizar medios de almacenamiento ¿existen controles para proteger el material sensible que pudiera tener información sensible?
¿Se destruyen o se sobreescriben en forma segura, los medios de almacenamiento que contienen material sensible, como por ejemplo, discos rígidos no removibles?
¿Se utilizan las funciones de borrado estándar?
¿En caso de ser documentos en papel, los mismos son físicamente destruidos?



Universidad Tecnológica Nacional
Rectorado

Comité de Seguridad de la Información
Coordinación General

Los documentos en papel y los medios informáticos conteniendo información sensible ¿se almacenan bajo llave, en gabinetes y/u otro tipo de mobiliario seguro cuando no están siendo utilizados?
¿Se desconecta de la red / sistema / servicio o se protege mediante contraseñas al inicio y sobre protectores de pantalla a las computadoras personales, terminales e impresoras asignadas a funciones críticas, cuando están desatendidas?
¿Se protegen los puntos de recepción y envío de correo postal y las máquinas de Fax no atendidas?
¿Se bloquean las fotocopiadoras fuera del horario normal de trabajo?
¿Se retira la información sensible o confidencial una vez impresa?
¿Existen controles para asegurar que el equipamiento, la información y el software no sean retirados de la sede del organismo sin autorización?
¿Se llevan a cabo comprobaciones periódicas destinadas a detectar el retiro no autorizado de activos del organismo?



Universidad Tecnológica Nacional
Rectorado

Comité de Seguridad de la Información
Coordinación General

8.1. SEGURIDAD FÍSICA Y AMBIENTAL	
¿Existen medidas de prevención contra software malicioso, (por ej. virus, troyanos; entre otros) a fin de evitar la ocurrencia de tales amenazas?	
¿Se encuentran separados los ambientes de desarrollo, prueba y operaciones del organismo?	
¿Se asegura la calidad de los procesos que se implementan en el ámbito operativo?	
¿Existe comunicación entre los sistemas de información? ¿Está regulada?	
¿Se garantiza la confidencialidad, integridad, disponibilidad de la información que se emite o se recibe por los distintos canales?	
¿Están definidos los procedimientos para el manejo de incidentes de seguridad y para la administración de los medios de almacenamiento?	
¿Se ha definido y documentado claramente por medio de una norma el uso de correo electrónico? ¿Se han definido y documentado controles para la detección y prevención del acceso no autorizado?	
¿Se han desarrollado procedimientos vinculados a la concientización de los usuarios en materia de seguridad, controles de acceso al sistema y administración de cambios?	



Comité de Seguridad de la Información
Coordinación General

8.2. DOCUMENTACIÓN DE LOS PROCEDIMIENTOS OPERATIVOS
¿Se documentaron los procedimientos operativos y sus modificaciones en esta Política?
El Responsable de Seguridad Informática ¿autoriza los procedimientos operativos?
¿Especifican los procedimientos instrucciones para la ejecución detallada de cada tarea?
¿Existen instrucciones para el procesamiento y manejo de la información?
¿Están definidos los requerimientos de programación de procesos, interdependencias con otros sistemas, tiempo de inicio de las primeras tareas de finalización de las mismas?
¿Existen instrucciones para el manejo de errores u otras condiciones de excepción que puedan surgir durante la ejecución de estas últimas?
¿Existen restricciones en el uso de utilitarios del sistema?
¿Se contacta personal de soporte en caso de presentarse dificultades operativas o técnicas imprevistas?
¿Existen instrucciones especiales para el manejo de salidas, salidas confidenciales, salidas fallidas?
Si se producen fallas en el sistema al reiniciar ¿existen procedimientos de recuperación?
¿Se registran actividades de instalación y mantenimiento de las plataformas de procesamiento?
¿Se monitorea el procesamiento y las comunicaciones?
¿Se documenta el inicio y cierre de sistemas?
Se documenta la programación y ejecución de procesos?
¿Se documenta la gestión de servicios?
¿Se documenta el resguardo de información?
¿Se documenta la gestión de incidentes de seguridad en el ambiente de procesamiento y comunicaciones?
¿Se documenta el reemplazo o cambio de componentes del ambiente de procesamiento y comunicaciones?
¿Se documenta el uso de correo electrónico?



Comité de Seguridad de la Información
Coordinación General

8.3. CONTROL DE CAMBIOS EN LAS OPERACIONES	
¿Existen procedimientos definidos para el control de los cambios en el ambiente operativo y de comunicaciones?	
Los cambios ¿son evaluados previamente en aspectos técnicos y de seguridad?	
¿Existe un responsable de controlar que los cambios en los componentes operativos y de comunicaciones no afecten la seguridad de los mismos ni de la información que soportan?	
¿Se evalúa el posible impacto operativo de los cambios previstos?	
¿Se verifica la correcta implementación de los cambios?	
¿Se asignan responsabilidades?	
¿Se cuenta con un registro de auditoria que contenga toda la información relevante de cada cambio implementado?	
Los procedimientos de control de cambios ¿contemplan la identificación de cambios significativos?	
¿Existe la aprobación formal de los cambios propuestos?	
¿Se realiza la planificación del proceso de cambio?	
¿Se prueba el nuevo escenario?	
¿Se informa detalladamente el cambio a todas las personas pertinentes?	
¿Se identifican las responsabilidades por cancelación de los cambios fallidos y la recuperación respecto de los mismos?	



Comité de Seguridad de la Información
Coordinación General

8.4. PROCEDIMIENTOS DE MANEJO DE INCIDENTES
¿Se establecen responsabilidades y procedimientos de manejo de incidentes?
¿Se garantiza una respuesta rápida, eficaz y sistemática a los incidentes relativos a Seguridad?
Se contemplan los incidentes relativos a la Seguridad?
¿Se contemplan los incidentes relativos a la seguridad ocasionados por fallas operativas?
¿Se contemplan los incidentes relativos a la seguridad ocasionados por código malicioso?
¿Se contemplan los incidentes relativos a la seguridad ocasionados por intrusiones?
¿Se contemplan los incidentes relativos a la seguridad ocasionados por fraude informático?
¿Se contemplan los incidentes relativos a la seguridad ocasionados por error humano?
¿Se contemplan los incidentes relativos a la seguridad ocasionados por catástrofes naturales?
¿Se comunican los incidentes a los funcionarios responsables pertinentes a la mayor brevedad posible?
¿Existen procedimientos para los planes de contingencia normales?
¿Se definieron las primeras medidas a adoptar para responder ante las contingencias?
¿Se analizó el incidente y se identificó su causa?
¿Se planificaron e implementaron las soluciones a efectos de evitar la repetición del incidente?
¿Se comunicó la contingencia a las personas afectadas o involucradas con la recuperación?
¿Se notificó de la medida adoptada ante la contingencia a la autoridad y/o organismos pertinentes?
¿Se registran listas de auditoría y evidencia?
En caso de problemas internos ¿se registran pistas de auditoría y evidencia?
¿Se registran pistas en relación con una probable violación contractual o
¿Se registran evidencias en caso de negociación de compensaciones por parte de los proveedores de software de servicios?
¿Se implementan controles detallados y formalizados de las acciones de recuperación respecto de las violaciones de la seguridad y de corrección de fallas del sistema?



Universidad Tecnológica Nacional
Rectorado

Comité de Seguridad de la Información
Coordinación General

¿Se brinda acceso a los sistemas y datos existentes sólo al personal claramente identificado autorizado?	
¿Se documentan en forma detallada todas las acciones de emergencia adoptadas?	
¿Se comunican las acciones de emergencia al titular de la unidad organizativa? ¿Se revisa su cumplimiento?	
¿Se verifica la integridad de los controles y sistemas del organismo con una periodicidad pre-establecida?	



Universidad Tecnológica Nacional
Rectorado

Comité de Seguridad de la Información
Coordinación General

8.5. SEPARACION DE FUNCIONES
¿Se separa la gestión o ejecución de ciertas tareas o áreas de responsabilidad a efectos de garantizar un adecuado control por oposición de intereses?
¿Se implementa el monitoreo de actividades?
¿Existen registros de auditoria con control periódico de los mismos?
¿Se cuenta con la documentación formal en caso de que resulte imposible efectuar la segregación de funciones?
¿Se toman recaudos para que ninguna persona pueda realizar actividades en áreas de responsabilidad única sin ser monitoreada?
¿Existe independencia entre el inicio de un evento su autorización?
¿Se separan actividades que faciliten connivencia para el fraude?
En caso de riesgo ¿se diseñan controles para evitar la connivencia? Especificar el tipo de controles.



Comité de Seguridad de la Información
Coordinación General

8.6. SEPARACION ENTRE INSTALACIONES DE DESARROLLO E INSTALACIONES OPERATIVAS	
¿Están separados físicamente los ambientes de desarrollo, prueba y operaciones?	
¿Se definieron y documentaron las normas para la transferencia de software del estado de desarrollo al estado operativo?	
¿Se ejecuta el software de desarrollo y de operaciones, en diferentes ambientes de operaciones, equipos, o directorios?	
¿Se separan las actividades de desarrollo y prueba, en entornos diferentes?	
¿Se impide el acceso a los compiladores, editores y otros utilitarios del sistema en el ambiente operativo, cuando no resulten indispensables para el funcionamiento del mismo?	
¿Se utilizan sistemas de autenticación y autorización independientes para los diferentes ambientes?	
¿Se manejan perfiles de acceso a los sistemas?	
¿Se prohíbe a los usuarios compartir contraseñas en estos sistemas?	
Las interfaces de los sistemas ¿identificarán claramente en qué instancia se está realizando la conexión?	
¿Se definen propietarios de la información para cada uno de los ambientes de procesamiento existentes?	
¿Tiene el personal de desarrollo acceso al ambiente operativo?	
En caso afirmativo ¿se estableció un procedimiento de emergencia para la autorización, documentación y registro de dichos accesos?	



Comité de Seguridad de la Información
Coordinación General

8.7. GESTIÓN DE INSTALACIONES EXTERNAS

En el caso de tercerizar la administración de las instalaciones de procesamiento ¿se acuerdan controles con el proveedor del servicio y se incluyen en el contrato los requerimientos de seguridad?

¿Se identifican las aplicaciones sensibles o críticas que resulte conveniente retener en el organismo?

¿Se cuenta con la aprobación de los propietarios de aplicaciones específicas?

¿Se identifican las implicancias para la continuidad de los planes de las actividades del organismo?

¿Se Cuenta con normas de seguridad específicas y el proceso de medición de su cumplimiento detallado?

¿Se asignan funciones específicas y procedimientos para monitorear todas las actividades de Seguridad?

¿Se definen las funciones y procedimientos de comunicación y manejo de incidentes relativos a la seguridad?

8.8. PLANIFICACION Y APROBACIÓN DE SISTEMAS

¿Se monitorean las necesidades de capacidad de los sistemas en operación y se proyectan las futuras demandas de capacidad, a fin de garantizar un procesamiento almacenamiento adecuado?

¿Se consideran los nuevos requerimientos de los sistemas y las tendencias actuales y proyectadas en el procesamiento de la información para el período estipulado de vida útil de cada componente?

¿Se informan las necesidades detectadas a las autoridades competentes para que puedan identificar y evitar potenciales inconvenientes que podrían generar una amenaza a la continuidad del procesamiento?

¿Se planifican acciones correctivas?



Universidad Tecnológica Nacional
Rectorado

Comité de Seguridad de la Información
Coordinación General

8.9. APROBACIÓN DEL SISTEMA	
¿Se establecen criterios de aprobación para nuevos sistemas de información, actualizaciones y nuevas versiones?	
¿Se solicita la realización de pruebas necesarias antes de su aprobación definitiva?	
¿Se verifica el impacto en el desempeño y los requerimientos de capacidad de las computadoras?	
¿Se garantiza la recuperación ante errores?	
¿Se preparan y ponen a prueba los procedimientos operativos de rutina según normas definidas?	
¿Se garantiza la implementación de un conjunto acordado de controles de seguridad?	
¿Se redactan procedimientos eficaces?	
¿Se elaboran disposiciones relativas a la continuidad de las actividades del organismo?	
¿Se asegura que la instalación del nuevo sistema no afectará en forma negativa los sistemas existentes, especialmente en los períodos pico de procesamiento?	
¿Afecta de manera considerable el nuevo sistema a la seguridad global del organismo?	
¿Se realiza capacitación en la operación y/o uso de nuevos sistemas?	



Comité de Seguridad de la Información
Coordinación General

8.10. PROTECCION CONTRA EL SOFTWARE MALICIOSO
¿Existen controles de detección y prevención para la protección contra el software malicioso?
¿Se desarrollaron procedimientos adecuados de concientización de los usuarios en materia de seguridad, controles de acceso al sistema y administración de cambios?
¿Se prohíbe el uso de software no autorizado por el organismo?
¿Se redactaron procedimientos para evitar los riesgos relacionados con la obtención de archivos y software desde redes externas, o a través de ella, o por cualquier otro medio, que indiquen las medidas de protección a adoptar?
¿Se instala y actualiza periódicamente el software de detección y reparación de virus, con capacidad para analizar computadoras y medios de almacenamiento, tanto como medida precautoria como rutinaria?
¿Se mantienen los sistemas con las últimas actualizaciones de seguridad disponibles?
¿Se prueban dichas actualizaciones en un entorno de prueba en caso de que constituyan cambios críticos a los sistemas?
¿Se revisa periódicamente el contenido del software y los datos de los sistemas que sustentan procesos críticos del organismo investigando formalmente la presencia de archivos no aprobados o modificaciones no autorizadas?
¿Se verifica, previo a su uso, la presencia de virus en archivos de medios electrónicos de origen incierto o en archivos recibidos a través de redes no confiables?
¿Se redactan procedimientos para verificar toda la información relativa a software malicioso, garantizando que los boletines de alerta sean exactos e informativos?
¿Se concientiza al personal acerca del problema de los falsos virus (<i>hoax</i>) y de cómo proceder frente a los mismos?



Comité de Seguridad de la Información
Coordinación General

9.1. CONTROL DE ACCESOS	
¿Existen políticas, normas y procedimientos para Control de Acceso Seguridad Informática?	
¿Se establecieron criterios para clasificar a la información contenida en la base de datos?	
¿Se identificaron los requerimientos de seguridad de cada una de las aplicaciones y su información conexas?	
Estos criterios de clasificación ¿establecen niveles de acceso para realizar alta, baja, consulta y modificación de los datos?	
¿Se definieron los perfiles de acceso de usuarios estándar agrupados por categorías?	
¿Qué base legislativa de la normativa vigente del organismo se utilizó para generar los perfiles de acceso de usuarios? ¿Se consideran todos los tipos de conexiones posibles?	
¿Existen reglas de control de acceso obligatorias? Indicar en comentarios cuál es el criterio.	
¿Se respeta la premisa “todo debe estar prohibido a menos que se permita expresamente”?	
¿Se ha establecido una división de funciones dentro del Área Informática?	
¿Existen normas y procedimientos para el control de cambio de versiones?	
¿Cuál es el método utilizado? Detallar.	
¿Controla el área de seguridad informática las actividades desarrolladas por estos usuarios?	
¿Cuáles son los criterios de control establecidos? Justificar.	
¿Se dispusieron controles sobre las modificaciones de perfiles de usuario? ¿Cuáles?	



Comité de Seguridad de la Información
Coordinación General

9.2. ADMINISTRACION DE ACCESOS DE USUARIOS	
¿Existen procedimientos formales para impedir el acceso no autorizado a la información?	
¿Contemplan dichos procedimientos, la asignación de derechos de acceso a los sistemas, bases de datos y servicios de información?	
¿Existe un Responsable de Seguridad Informática?	
¿Definió dicho Responsable de Seguridad Informática un procedimiento formal de registro de usuarios para otorgar y revocar el acceso a todos los sistemas, bases de datos y servicios de información multiusuario?	
¿Se utilizan, cuando resulte conveniente, identificadores de usuario únicos debido a razones operativas?	
¿Tiene el usuario autorización del propietario de la información para el uso del sistema, base de datos o servicio de información?	
El nivel de acceso otorgado en todos los casos ¿es adecuado para el propósito de la función del usuario y es coherente con la Política de Seguridad del organismo?	
¿Se ha entregado a los usuarios un detalle escrito de sus derechos de acceso?	
¿Suscribieron todos los usuarios declaraciones manifestando que comprenden las condiciones para el acceso?	
¿Se garantiza que los proveedores de servicios no otorguen acceso hasta que se hayan completado los procedimientos de autorización?	
¿Se cuenta con un registro formal de todas las personas autorizadas, registradas para utilizar el servicio?	
¿Se cancelan inmediatamente los derechos de acceso de los usuarios que - Cambiaron sus tareas,	
¿Se cancelan inmediatamente los derechos de acceso de los usuarios que - A quienes se les revocó su autorización,	
¿Se cancelan inmediatamente los derechos de acceso de los usuarios que - Se desvincularon del organismo?	
¿Se efectúan revisiones periódicas con el objeto de - Cancelar identificadores y Cuentas de usuario redundantes;	
¿Se efectúan revisiones periódicas con el objeto de - Inhabilitar Cuentas inactivas por más de sesenta (60) días;	
¿Se efectúan revisiones periódicas con el objeto de - Eliminar Cuentas inactivas por más de ciento veinte (120) días?	



Universidad Tecnológica Nacional
Rectorado

Comité de Seguridad de la Información
Coordinación General

Las excepciones ¿están debidamente justificadas y aprobadas?	
¿Se incluyen cláusulas en los contratos de obra y de servicios o de relación de dependencia que especifiquen sanciones para quienes intenten accesos no autorizados?	
¿Vuelven a asignarse los identificadores de usuarios redundantes?	
¿Se incluyen cláusulas en los contratos del personal que especifiquen sanciones si los agentes intentan accesos no autorizados?	



Comité de Seguridad de la Información
Coordinación General

9.3. ADMINISTRACION DE ACCESOS DE PRIVILEGIOS
¿Se limita y controla la asignación y el uso de privilegios?
¿Existe un proceso de autorización formal para la asignación de privilegios en los sistemas multiusuario?
En dicho proceso de autorización formal, ¿se han identificado los privilegios asociados a cada producto del sistema (ej. sistema operativo, sistema de administración de bases de datos y aplicaciones)?
¿Se toman en cuenta las categorías de personal a las cuales deben asignarse los productos?
¿Se asignan los privilegios sobre la base de la necesidad de uso y, evento por evento (ej. el requerimiento mínimo para su rol funcional)?
¿Se mantiene un proceso de autorización y un registro de todos los privilegios asignados?
¿Se establece un período de vigencia para el mantenimiento de los privilegios sobre el uso que se hará de los mismos?
¿Se revocan los privilegios al finalizar el periodo de vigencia establecido? ¿Se promueve el desarrollo y uso de rutinas del sistema para evitar la necesidad de otorgar privilegios a los usuarios?
Los propietarios de la información ¿son los encargados de aprobar la asignación de privilegios a usuarios?
El Responsable de Seguridad Informática ¿controla la asignación de privilegios a usuarios?
¿Existe un proceso de administración formal para la asignación de contraseñas?
¿Se requirió a los usuarios que suscriban una declaración por la cual se comprometen a no difundir sus contraseñas personales?
¿Se encuentra esta declaración incluida en el Compromiso de Confidencialidad?
Las contraseñas provisorias asignadas cuando los usuarios olvidan su contraseña se suministran sólo una vez identificado el usuario?
¿Los usuarios dan acuse de recibo de la recepción de la contraseña de carácter provisorio?
¿Se almacenan las contraseñas sólo en sistemas informáticos protegidos?
El Comité de Seguridad de la Información ¿Dispuso la utilización de otras tecnologías de identificación y autenticación de usuarios, por ej. la biométrica?
¿Se realiza la verificación de firma y uso de autenticadores de hardware (por ej. las tarjetas de circuito integrado)?
¿Responde la utilización de dichas tecnologías a la evaluación de riesgos realizada por el Responsable de Seguridad Informática juntamente con el Responsable del Área de Informática?



Universidad Tecnológica Nacional
Rectorado

Comité de Seguridad de la Información
Coordinación General

Los sistemas operativos de red ¿están configurados de manera tal que las contraseñas tengan hasta ocho caracteres para cuentas administradoras y hasta seis caracteres para cuentas de usuarios comunes?
¿Se suspende o bloquea permanentemente al usuario luego de tres (3) intentos de ingresar una contraseña incorrecta, siendo responsabilidad del usuario solicitar su rehabilitación al Responsable de Administración de Seguridad del organismo?
¿Se solicita a los usuarios el cambio de la contraseña cada 30 días?
¿Se impide el uso de las últimas doce (12) contraseñas utilizadas?
¿Se toman los recaudos necesarios a fin de garantizar que los usuarios cambien en su primer ingreso al sistema las contraseñas iniciales que les son asignadas?
¿Existen procedimientos para la administración de contraseñas críticas?
¿Están protegidas con un nivel de complejidad mayor al habitual?
¿Participan al menos dos personas en la definición de las contraseñas críticas?
¿Se registra el uso de cuentas y contraseñas críticas, se documentan las causas del mismo se identifica a quien las utilizó?
¿Se renueva la contraseña una vez utilizada o con posterioridad a un período en el que no fue utilizada?
¿Se registran todas las actividades realizadas con las contraseñas críticas?



Comité de Seguridad de la Información
Coordinación General

9.4. REVISION DE DERECHOS DE ACCESO DE USUARIOS
El propietario de la información ¿lleva a cabo un proceso formal a fin de revisar los derechos de acceso de los usuarios?
En dicho proceso ¿se revisan los derechos de acceso de los usuarios a intervalos no mayores de seis (6) meses o después de cualquier cambio?
¿Se revisan las autorizaciones de privilegios especiales de derechos de acceso a intervalos no mayores de tres (3) meses?
A fin de garantizar que no se obtengan privilegios no autorizados ¿se revisan las asignaciones de privilegios de todos los usuarios a intervalos no mayores de seis (6) meses?
¿Se siguen “mejores buenas prácticas” en materia de seguridad en la selección y uso de contraseñas?
¿Cumplen los usuarios con la directiva de mantener las contraseñas en secreto?
¿Se solicita el cambio de la contraseña siempre que haya un indicio de compromiso de sistema o de las contraseñas?
¿Seleccionan los usuarios contraseñas de calidad, de acuerdo con las prescripciones informadas por el propietario de información que se trate?
¿Se cambian las contraseñas provisorias en el primer inicio de sesión luego de recibidas?
¿Se evita incluir contraseñas en los procesos automatizados de inicio de sesión, por ejemplo, aquellas almacenadas en una tecla de función o macro?
¿Garantizan los usuarios que los equipos desatendidos sean protegidos adecuadamente contra accesos no autorizados?
El Responsable de Seguridad Informática ¿dispone las tareas de concientización a todos los usuarios y contratistas acerca de los requerimientos y procedimientos de seguridad, para la protección de equipos desatendidos, así como de sus responsabilidades?
¿Concluyen los usuarios las sesiones activas al finalizar las tareas o bien se protegen mediante un mecanismo de bloqueo adecuado?
¿Se protegen las PCs o terminales contra usos no autorizados mediante un bloqueo de Seguridad o control equivalente?



Comité de Seguridad de la Información
Coordinación General

9.5. CONTROL DE ACCESO A LA RED	
¿Existe una política de utilización de los servicios de red?	
¿Se controla el acceso a los servicios de red internos y externos?	
¿Se encuentra el otorgamiento de los servicios y recursos de red a cargo del Responsable del Área Informática por pedido expreso de un titular del área organizativa?	
¿Existen procedimientos para la activación y desactivación del derecho de acceso a redes?	
¿Están identificadas las redes y servicios de red a los cuales se permite el acceso mediante normas y procedimientos?	
¿Existen procedimientos de gestión para proteger el acceso a las conexiones y servicios de red acordes a la política de control de acceso del organismo?	
¿Existen aplicativos o servicios a los que deban acceder usuarios que se encuentran fuera de la red del organismo?	
¿Están claramente definidas las personas con capacidad para solicitar permisos de acceso a servicios y recursos dentro del organismo?	
Cada pedido de acceso a servicios y/o recursos, ¿es evaluado por el responsable del Área de Informática?	
¿Cuáles son los procedimientos para la activación y desactivación de derechos de acceso a redes definidos por el organismo?	
¿Se encuentran identificadas y/o definidas todas las redes del organismo?	
¿Qué procedimientos existen para diferenciar y así determinar las redes y servicios de red que existen en el organismo?	
¿Qué tipo de controles se efectúa para proteger el acceso a las conexiones y servicios de red?	
¿Existen dispositivos que direccionen el tráfico de las redes en caso de estar segmentadas? En caso de respuesta afirmativa, enumerar los mismos indicando marca y modelo además de las políticas / medidas de control implementadas.	



Comité de Seguridad de la Información
Coordinación General

9.6. CAMINO FORZADO
¿Está controlado el camino de las comunicaciones?
¿Existen limitaciones en la elección de la ruta entre la terminal de usuario y los servicios a los cuales se encuentra autorizado a acceder?
¿Se asignan líneas o números telefónicos de uso exclusivo para acceder a los recursos? En caso afirmativo, el acceso a estas líneas ¿es directo o vía <i>call back</i> ?
¿Existen <i>gateways/firewalls</i> en el organismo que direccionen los puertos específicos a su correspondiente aplicación y a la vez descarten los paquetes con puertos de destino que no estén específicamente direccionados?
¿Reconocen los aplicativos del organismo niveles de usuarios?
¿Qué medidas/políticas de restricción del uso indebido de Internet existen en el organismo?
¿Se controlan -en caso de existir- los <i>logs</i> de acceso que generan los distintos dispositivos de control de acceso?
¿Están divididos los grupos de usuarios del organismo en redes privadas virtuales o dominios lógicos?
¿Se restringe el acceso a redes estableciendo dominios lógicos separados en redes virtuales separadas?

9.7. AUTENTICACION DE USUARIOS PARA CONEXIONES EXTERNAS
¿Están claramente identificados los usuarios con permiso de acceso externo al organismo?
¿Qué método de autenticación es utilizado para los usuarios especialmente autorizados para el ingreso desde el exterior?
¿Existen reglas específicas de los nodos externos autorizados a ingresar a la red/servicios y/o aplicaciones del organismo?
¿Se efectúan en el organismo diagnósticos remotos sobre los distintos puntos de acceso para verificar cuáles son los puertos habilitados?
¿Existe algún dispositivo o software que alerte al Responsable de Seguridad Informática cuando uno de estos diagnósticos se está efectuando? En caso afirmativo, enumerar los dispositivos y/o software utilizados.



Comité de Seguridad de la Información
Coordinación General

9.8. SUBDIVISION DE REDES

¿Está dividida la red en dominios lógicos separados?

¿Se implementan perímetros de seguridad?

¿Se llevan a cabo mediante *gateways* o redes privadas virtuales?

En caso de existir otra subdivisión de redes, informar mediante qué dispositivos y/o software se efectúa esa subdivisión.

En caso de existir la subdivisión de redes-dominios, ¿qué criterios de aglutinamiento se utilizaron para la confección de los grupos?

9.9. ACCESO A INTERNET

¿Se controla el uso de Internet?

¿Existen pautas de utilización de Internet?

¿Existen procedimientos que los usuarios deben seguir para solicitar el acceso a Internet en el caso de existir políticas de restricción para su utilización?

¿Existen dispositivos de hardware o software utilizados para el monitoreo del uso de Internet?

¿Se notifica a los usuarios cuando infringen alguna medida/norma establecida?

¿Se implementan controles para limitar la capacidad de conexión?

9.10. CONTROL DE RUTEO

¿Se implementó un control de ruteo de red?

¿Se verifican las direcciones de origen y destino?

¿Existe autenticación de protocolos de ruteo, ruteo estático, traducción de direcciones y listas de control de acceso?

¿Existe en el organismo, documentación en la que figuren las pautas de propiedades de seguridad de los servicios de red?

¿Se revisa periódicamente la documentación y, en consecuencia, las medidas implementadas?

¿Existe la identificación automática de terminales?

¿Se cuenta con el detalle de transacciones permitidas por terminal?

¿Realiza el Responsable de Seguridad Informática una evaluación de riesgos para determinar el procedimiento adecuado del acceso al sistema operativo?

¿Se utilizan criterios para realizar la evaluación?



Comité de Seguridad de la Información
Coordinación General

9.11. PROCEDIMIENTOS DE CONEXIÓN DE TERMINALES

¿Existe un procedimiento de conexión de terminales que minimice la oportunidad de acceso no autorizado?

¿Se mantienen en secreto los identificadores de sistemas o aplicaciones hasta tanto se ha llevado a cabo el proceso de conexión?

¿Existe un aviso donde figure que sólo usuarios autorizados pueden acceder a la computadora?

¿Se divulga la mínima información posible del sistema y sin mensajes de ayuda?

En caso de error se indica la parte en la que el error se produjo?

¿Estableció el organismo el tope máximo de intentos fallidos en la conexión?

¿Cuentan todos los usuarios con un identificador de usuario de uso personal exclusivo?

¿Se utiliza algún método para la autenticación física?

¿Se lleva el registro de las ID de usuarios?

¿Existe un resguardo eficiente de las ID establecidas por cada usuario?

9.12. SISTEMA DE ADMINISTRACIÓN DE CONTRASEÑAS

¿Estableció el organismo un tiempo adecuado de duración de contraseña?

¿Cuenta el organismo con un sistema de detección de contraseñas ya utilizadas?

9.13. USO DE UTILITARIOS DEL SISTEMA

¿Se utilizan procedimientos de autenticación para utilitarios del sistema?

¿Se limita en el organismo el uso de utilitarios del sistema a la cantidad mínima viable de usuarios fiables autorizados?

¿Se han establecido mecanismos a fin de evitar que las personas ajenas al organismo tomen conocimiento de la existencia y modo de uso de los utilitarios instalados?

¿Se hace una distinción entre el tratamiento a los utilitarios del sistema y software de aplicaciones?

¿Se dispusieron autorizaciones para el uso *ad-hoc* de utilitarios del sistema?

¿Se limitó la disponibilidad de utilitarios de sistema?

¿Queda registrado todo uso de los mismos?

Los criterios de autenticación de los programas ¿son más estrictos que los utilizados para identificar a los usuarios?

¿Se procede a remover todo el software basado en utilitarios y de sistemas innecesarios?

¿Se establecieron los niveles de autorización?

¿Existe un nivel de riesgo que justifique la instalación de una alarma silenciosa?



Comité de Seguridad de la Información
Coordinación General

9.14. TIEMPO MUERTO

¿Estableció el organismo la medida de seguridad del tiempo muerto para las distintas terminales que sirvan a sistemas de alto riesgo?

¿Los tiempos muertos (*time-out*) son suficientes al requerido para determinadas consultas para bases de datos?

La herramienta de desconexión, ¿limpia la pantalla de la terminal y cierra la sesión de aplicación y la de red al concluir?

9.15. HORARIO DE CONEXIÓN

¿Se utilizan lapsos predeterminados de corta duración para transmisión de archivos en lote?

¿Se limitan los horarios de conexión al horario normal de oficina?

Los agentes que no tengan restricciones horarias ¿están debidamente registrados?

9.16. RESTRICCIONES AL ACCESO A LA INFORMACIÓN

Los accesos a la información ¿cumplen con la política de control de acceso definida por el organismo?

¿Se restringe el conocimiento de los usuarios acerca de la información o los controles?

¿Se controlan los derechos a acceso de los usuarios?

¿Se restringe el acceso a la información por fuera del sistema encargado de su procesamiento?

9.17. MONITOREO DEL USO DE LOS SISTEMAS

¿Dispone el área de seguridad informática de interfaces para controlar el acceso a los aplicativos?

¿Se ha definido un usuario que realice controles sobre el uso y las actividades de los aplicativos?

¿Se realizan informes sobre las actividades y el uso de los aplicativos? ¿Con qué frecuencia?

¿Se autoriza a los usuarios iniciar sesiones duplicadas?

¿Existen controles sobre las claves de acceso a los aplicativos?

En las áreas que utilizan sistemas sensibles ¿se controla la salida de los mismos (áreas de operaciones, centro de impresión)?

Sobre las sesiones usuario ¿se establecieron controles de caducidad, tiempos de espera, etc.?

¿Se establecieron controles sobre las áreas de base de datos y procesamiento?



Comité de Seguridad de la Información
Coordinación General

9.18. AISLAMIENTO DE LOS SISTEMAS SENSIBLES
¿Se han establecido criterios para evaluar la criticidad de los sistemas?
¿Existen sistemas sensibles que requieran un ambiente informático dedicado?
¿Se toman medidas al tener que ejecutar sistemas sensibles en un ambiente compartido?
¿Se tiene en cuenta la seguridad en la administración de las copias de respaldo?
¿Qué recaudos de seguridad se adoptan para estos sistemas frente a ABM y Modificaciones de Perfiles de Usuarios, Políticas de Resguardo, Plan de Contingencia y de Recupero frente a Desastres?
¿Se han contemplado los sistemas críticos en las políticas de seguridad?
¿Poseen estos sistemas toda la información completa relacionada con el diseño, desarrollo, producción (versiones) y usuario?
¿El área de Seguridad Informática posee controles especiales sobre estas aplicaciones?
¿Establecen el responsable del área sensible y el área de seguridad pautas para la ejecución resguardo de estos aplicativos?
¿Se realizan pruebas sobre los Planes de Resguardo (<i>back-up</i>), Planes de Contingencia, Planes de Recupero ante Desastres?
¿Existen archivos de registros de acceso al sistema?
¿Incluyen identificación del usuario?
¿Incluyen fecha hora de inicio terminación?
¿Incluyen identidad o ubicación de la terminal?
¿Incluyen intentos exitosos fallidos de acceso al sistema?
¿Incluyen intentos exitosos y fallidos de acceso a datos y otros recursos?
¿Se aplica la política de retención de registros?
¿Existe un cronograma de depuración de registros en línea?
¿Cumple el cronograma de depuración de registros en línea con las normas vigentes y las necesidades propias del organismo?



Comité de Seguridad de la Información
Coordinación General

9.19. MONITOREO DEL USO DE LOS SISTEMAS
¿Existen procedimientos de control de actividades de los usuarios respecto del uso de las instalaciones de procesamiento de la información?
¿Se advirtió a los empleados sobre la posibilidad del control y monitoreo de las actividades del sistema?
¿Conoce el personal el alcance preciso del uso adecuado de los recursos informáticos?
¿Se corresponden estos controles con la evaluación de riesgos de los Responsables del Área Informática y Seguridad Informática?
¿Se monitorean accesos no autorizados?
¿Se incluyen los detalles de identificación de usuario?
¿Se registran fecha hora de eventos clave?
¿Se distinguen tipos de eventos?
¿Se registran los archivos a los que se accede?
¿Se registran los utilitarios y programas utilizados?
¿Se monitorean todas las operaciones que requieren privilegios especiales (como la utilización de cuenta de supervisor)?
¿Se monitorea el inicio cierre del sistema?
¿Se monitorea la conexión y desconexión de dispositivos de Ingreso y Salida de información o que permitan copiar datos?
¿Se monitorea el cambio de fecha/hora?
¿Se monitorean los cambios en la configuración de la seguridad?
¿Se monitorea el alta de servicios?
¿Se monitorean intentos de accesos no autorizados como intentos fallidos?
¿Se monitorean violaciones de la Política de Accesos y notificaciones para gateways de red y firewalls?
¿Existen alertas de sistema de detección de intrusiones?
¿Existen alertas o mensajes de consola?
¿Existen alarmas del sistema de administración de redes?
¿Existen alarmas de accesos remotos al sistema?



Comité de Seguridad de la Información
Coordinación General

9.20. FACTORES DE RIESGO
¿Se realiza una evaluación de la criticidad de los procesos de la aplicación?
¿Se realiza una evaluación de la sensibilidad de la información involucrada?
¿Existen antecedentes de infiltración y uso inadecuado del sistema?
¿Se realiza una evaluación del alcance de la interconexión de sistema?
¿Existen normas internas sobre los eventos críticos para la operatoria que deban ser registrados?

9.21. REGISTRO Y REVISIÓN DE EVENTOS
¿Existe un procedimiento de registro y revisión de los registros de auditoria que produzcan informes de las amenazas detectadas contra los sistemas y los métodos utilizados?
¿Definieron el propietario de la información y el Responsable de Seguridad Informática la periodicidad de las revisiones de acuerdo con la evaluación de riesgos efectuada?
¿Indica el procedimiento cuáles registros se copiarán en registros auxiliares?
¿Se utilizan herramientas de auditoria o utilitarios para la evaluación de los registros? Quién lo dispuso?
¿Existen controles de acceso para la desactivación de la herramienta de registro?
¿Existen controles de acceso para la alteración de mensajes registrados?
¿Existen controles de acceso para la edición o supresión de archivos de registro?
¿Se controla la saturación de un medio de soporte de archivos de registro?
¿Se controla la falla en los registros de los eventos?
¿Está definida y se controla la sobre escritura de registros?
La Auditora Interna ¿tiene acceso a los registros?



Comité de Seguridad de la Información
Coordinación General

9.22. SINCRONIZACIÓN DE RELOJES
¿Los equipos que generan registros tienen correctamente configurados los relojes?
¿Existen procedimientos de ajuste de relojes que comparen los mismos con una fuente externa confiable y efectúen correcciones en caso de desviaciones?
¿Se puede garantizar la información del organismo en todo dispositivo móvil y/o removible (Ej. Notebooks, Laptop, PDA, teléfonos, almacenamientos removibles tales como CDs, DVDs, disquetes, tapes, cualquier almacenamiento de conexión USB)?
¿Se utiliza una protección física adecuada para estos dispositivos?
¿Se dispone de acceso seguro restringido a los dispositivos?
¿Se controla la utilización de los dispositivos en lugares públicos? ¿Se controla el acceso a los sistemas de información y servicios del organismo a través de dichos dispositivos?
¿Se utilizan las técnicas criptográficas para la transmisión de la información clasificada?
¿Se cuenta con mecanismos de resguardo de la información contenida en los dispositivos?
¿Se dispone de protección contra software malicioso?
¿Se provee capacitación especial para los usuarios que utilizan los dispositivos móviles?
¿Permanece el usuario siempre cerca del dispositivo?
¿Deja el usuario desatendido los equipos?
¿Se advierte al usuario sobre el valor del dispositivo que tiene a su cargo?
¿Posee el dispositivo identificación del organismo?
¿Posee el dispositivo inscripciones o datos técnicos?
¿Lleva el dispositivo la información cifrada?
¿Se dispone para dichos dispositivos móviles de planes de contingencia ante cualquier incidente o eventualidad en los cuales estuvieran expuestos los sistemas de información del organismo?



Comité de Seguridad de la Información
Coordinación General

9.23. TRABAJO REMOTO
El usuario que solicita el acceso remoto ¿es autorizado por el responsable de la unidad organizativa y el Responsable de Seguridad Informática?
¿Existen procedimientos para el trabajo remoto?
¿Existen procedimientos para el ambiente de trabajo remoto propuesto?
¿Estén procedimientos para la seguridad física existente en el sitio de trabajo remoto, tomando en cuenta la seguridad física del edificio y del ambiente local?
¿Existen procedimientos para los requerimientos de seguridad de comunicaciones, teniendo en cuenta la necesidad del acceso remoto y la sensibilidad de la información?
¿Existen procedimientos para controlar la amenaza de acceso no autorizado a la información o de utilización de recursos por parte de terceros que acceden al lugar (ej. familia y amigos)?
¿Existen procedimientos para evitar la instalación / desinstalación de software no provisto por el organismo en los dispositivos móviles?
¿Existen procedimientos para equipar de mobiliario para el almacenamiento y equipamiento adecuado para el desempeño de las actividades de trabajo remoto?
¿Existen procedimientos para los trabajos permitidos, sus horarios, accesos e información que queda almacenar en el equipo remoto?
¿Existen procedimientos para incluir la seguridad física de los dispositivos utilizados ara el trabajo remoto?
¿Existen procedimientos para una adecuada protección del enlace de comunicaciones utilizado durante el acceso remoto? ¿Existen reglas para orientar a los familiares y visitantes que accedan al equipo a la información?
¿Existen procedimientos para proveer el hardware y su soporte?
¿Existen procedimientos para proveer el software y su mantenimiento?
¿Existen procedimientos para el <i>backup</i> y la continuidad de las operaciones?
¿Existen procedimientos para efectuar auditorias y monitoreos de la seguridad?
¿Existen procedimientos para realizar la anulación de las autorizaciones, de accesos y devolución del equipo cuando finalicen las actividades remotas?
¿Se realizan auditorias especificas para los casos de acceso remoto?



Comité de Seguridad de la Información
Coordinación General

10.1. DESARROLLO Y MANTENIMIENTO DE SISTEMAS

¿Se han planificado, documentado y ejecutado los requerimientos de seguridad de las etapas de Desarrollo, Implementación y Mantenimiento del sistema?

Los controles implementados ¿son en su mayoría automáticos o manuales?

¿Existe un procedimiento que durante la etapa de análisis y diseño del sistema incorpore los controles de seguridad a los requerimientos del sistema?

¿Se incluye una etapa de evaluación de riesgos previa al diseño?

¿Los controles de seguridad son proporcionales en costo y dedicación al valor del bien a proteger?
¿Están en concordancia con una adecuada evaluación de riesgo?

10.2. SEGURIDAD EN LOS SISTEMAS DE APLICACION

¿Se ha logrado consenso entre el Responsable de Seguridad Informática, el responsable del sistema y el Auditor de Sistemas de la UAI al definir los controles que requerirá el sistema a ser desarrollado o adquirido?

¿Se han definido los requerimientos de seguridad y se han establecido los controles apropiados en la etapa de diseño?

¿Existen registros de auditoria que controlen la validación de los datos de entrada, salida y procesamiento interno?

¿Se han incorporado reglas de validación de campos en los programas o formularios de entrada de datos o en la definición de las tablas de la base de datos?

¿Se han definido y documentado los métodos de protección de la información crítica?

10.3. CONTROLES CRIPTOGRAFICOS Y ALGORITMOS DE CIFRADO

¿Se han Implementado controles criptográficos en el caso de una aplicación que ermita el envío de mensajes?

¿Que tipos de controles se implementan en cada caso?

¿Se desarrollan procedimientos respecto de la administración de claves, recuperación de información cifrada, en caso de pérdida, compromiso o daño?

¿Qué algoritmos de cifrado simétrico y/o asimétrico se utilizan y cuál es su longitud de clave?

¿Se identificó el nivel requerido de protección sobre base de la evaluación de riesgos la calidad del algoritmo utilizado?



Comité de Seguridad de la Información
Coordinación General

10.4. FIRMA DIGITAL

¿Se garantiza que las claves criptográficas utilizadas para realizar firmas digitales no se empleen nunca en ningún otro proceso de cifrado de información?

Al usar firmas digitales ¿se cumple con la legislación pertinente (Ley 25.506- Decreto N° 2628/02 el conjunto de normas complementarias)?

¿Se utilizan servicios de no repudio ante una disputa acerca de la ocurrencia de un evento o acción?

10.5. ADMINISTRACION DE CLAVES

¿Se ha implementado un sistema de administración de claves criptográficas?

¿Utiliza el organismo técnicas criptográficas de clave pública y clave privada?

¿Se protegen las claves contra la modificación y/o destrucción, copia o divulgación?

¿Se protege el equipamiento destinado a generar, almacenar y archivar claves?

¿Se han redactado normas, procedimientos y métodos de administración de claves para generar, almacenar, actualizar, revocar, recuperar, archivar y destruir las mismas?

¿Tienen las claves fechas de entrada caducidad de vigencia?

¿Se cuenta con certificados de clave pública?

10.6. SEGURIDAD DE LOS ARCHIVOS DEL SISTEMA

¿Se garantiza que los desarrollos y actividades de soporte a los sistemas se realicen de manera segura?

¿Se controla el acceso a los archivos de sistema?

¿Cómo se implementa el control del software operativo?

¿Existe un único responsable para cada aplicación adquirida o desarrollada?

¿Se impide que programadores y analistas de desarrollo o mantenimiento accedan a los ambientes de producción?

¿Existe la figura de “implementador”? En caso de respuesta afirmativa cuáles son sus funciones?



Comité de Seguridad de la Información
Coordinación General

10.7. DATOS DE PRUEBA DEL SISTEMA

¿Existen normas o procedimientos para proteger los datos de prueba del sistema?

¿Existe una fuente de extracción concreta de los datos de prueba?

¿Existen casos en los que las pruebas se realizan sobre las bases de datos operativas?

Cuando se realiza una copia de la base operativa ¿se solicita autorización formal?

¿Se elimina la copia una vez finalizadas las pruebas?

¿Se ha realizado la puesta a punto de los programas y del sistema mediante juegos de pruebas parciales y totales?

10.8. CONTROL DE CAMBIOS A DATOS OPERATIVOS

La modificación, actualización o eliminación de los datos operativos ¿se realiza siempre por los sistemas que procesan dichos datos y no por modificación directa?

¿Existen situaciones excepcionales en las que algún cambio se realiza “por fuera del sistema”? ¿Qué recaudos se toman?

10.9. BIBLIOTECAS DE PROGRAMAS FUENTES

¿Se ha establecido que todo programa objeto o ejecutable en producción tenga un único programa fuente asociado a su origen?

¿Existe un adecuado control de acceso a las bibliotecas de programas fuentes?

¿Se ha implementado un formulario de solicitud de modificación de programas una hoja de seguimiento de los casos de la modificación?

¿Existe un administrador de programas fuentes independiente del sector de desarrollo mantenimiento?

¿Se mantiene en todo momento la correlación programa fuente/ejecutable, el registro de uso y la gestión actualizada de todos los cambios y versiones?

¿Se impide que el administrador tenga permisos de modificación sobre los programas fuentes bajo su custodia?

¿Cuenta el organismo con un procedimiento que garantice que toda vez que el módulo fuente se migre a producción, se cree el código ejecutable correspondiente en forma automática?

¿Se asegura que no se preserven programas fuentes históricos (que no sean los correspondientes a los programas operativos) en el ambiente de producción?

¿Se encuentra prohibido el acceso a todo operador y/o usuario de aplicaciones a los ambientes y a las herramientas que permitan la generación /o manipulación de los programas fuente?

¿Se efectúan copias de respaldo de los programas fuente?



Comité de Seguridad de la Información
Coordinación General

10.10. SEGURIDAD DE LOS PROCESOS DE DESARROLLO Y SOPORTE

¿Existen procedimientos formales para minimizar los riesgos de alteración de los sistemas de información?

¿Existe un responsable único para cada aplicación desarrollada internamente o adquirida a un proveedor externo? ¿Fue designado formalmente?

¿Los cambios propuestos tienen la autorización de los usuarios y/o del propietario de la información?

¿Pueden los cambios comprometer la integridad de los controles y procedimientos?

¿Se mantiene un control de versiones para todas las actualizaciones de software?

¿Se garantiza que la implementación se llevará a cabo minimizando la discontinuidad de las actividades?

¿Existe un encargado para efectuar el pasaje de los objetos modificados del ambiente de desarrollo al ambiente de producción?

10.11. REVISION TECNICA DE LOS CAMBIOS EN EL SISTEMA OPERATIVO

Toda vez que sea necesario realizar un cambio en el sistema operativo ¿Se revisan los sistemas de manera que no produzcan impactos en su funcionamiento o seguridad?

¿Contemplan procedimientos de integridad incluidos en el plan de tareas y presupuesto del organismo?

¿Se informan los cambios al sistema operativo con anterioridad a su implementación?

10.12. CAMBIO DE PAQUETES DE SOFTWARE

¿Está prohibida la modificación de paquetes de software suministrados por proveedores?

En caso de resultar imprescindible su modificación ¿se obtiene el consentimiento del proveedor?

¿Se retiene el software original?

¿Se determinó la conveniencia de que la modificación sea efectuada por el organismo, por el proveedor o por un tercero?

10.13. CANALES OCULTOS Y CODIGO MALICIOSO

¿Se sospecha la existencia de canales ocultos o código malicioso? ¿Se adquieren todos los programas, sin excepción, a proveedores acreditados?

¿Se examinan los códigos fuente siempre que es posible?

¿Se controla el acceso las modificaciones al código instalado?

¿Se efectúan tareas de monitoreo para detectar posible código malicioso?

¿Se dispone de herramientas preventivas para evitar la infección del software con código malicioso?



Comité de Seguridad de la Información
Coordinación General

10.14. DESARROLLO EXTERNO DE SOFTWARE
¿Existen acuerdos de licencias, propiedad de códigos y derechos de propiedad intelectual?
¿Constan requerimientos contractuales con respecto a la calidad del código la existencia de garantías?
¿Se incluyen auditorías y revisiones de código?
¿Interviene el funcionario a cargo del Área Legal y el Auditor de Sistemas de la UAI de la empresa en la definición de los contratos con terceros para el desarrollo de software?
¿Existe un procedimiento documentado que contemple los puntos a tener en cuenta para el caso de tercerización del desarrollo del software?
¿Se han incorporado reglas de validación de campos en los programas o formularios de entrada de datos o en la definición de las tablas de la base de datos?
¿Se han definido y documentado los métodos de protección de la información crítica?
¿Existe una carpeta actualizada con la documentación del sistema?
La definición de los controles a ser exigidos en el sistema a ser desarrollado o adquirido ¿fue una acción conjunta del Responsable de Seguridad Informática, el Responsable del Sistema y el Auditor de Sistemas de la UAI?
Previo a la etapa de diseño ¿se ha realizado una evaluación de riesgos respecto a la seguridad de la información que manejará el sistema?
En la etapa de diseño ¿se han definido los requerimientos de seguridad y se han establecido los controles apropiados?
En la etapa de diseño ¿se han definido las reglas de validación de los datos de entrada del contenido de los campos de cada tabla?
En la etapa de diseño ¿se han definido procedimientos para realizar revisiones periódicas de contenido de campos claves en las tablas?
En la etapa de diseño ¿se han definido procedimientos para eliminar o minimizar los riesgos de fallas de procesamiento del sistema puesto en operación?
En el caso de una aplicación que permite el envío de mensajes ¿se han implementado controles criptográficos para el envío de los mismos?
¿Se han implementado procedimientos de validación de los resultados de la ejecución del sistema?
¿Existe un responsable único, para cada aplicación desarrollada internamente o adquirida a un proveedor externo, designado formalmente?
¿Se realiza la separación o segregación de funciones entre el personal de desarrollo el personal de implementación de los sistemas?
¿Existe un procedimiento documentado que contemple los puntos a tener en cuenta para el caso de tercerización del desarrollo del software?



Comité de Seguridad de la Información
Coordinación General

11.1. ADMINISTRACIÓN DE LA CONTINUIDAD DE LAS ACTIVIDADES DEL ORGANISMO
¿Es el Comité de Seguridad de la Información el responsable de la coordinación del desarrollo de los procesos que garanticen la continuidad de la actividad del organismo?
¿Se han definido objetivos organizacionales de las herramientas de procesamiento de información?
¿Está la administración de la continuidad de las actividades del organismo incorporada a los procesos y estructura del mismo?
¿Se han identificado y priorizado los procesos críticos de las actividades del organismo?
¿Comprenden los integrantes del organismo los riesgos que el mismo enfrenta, en términos de probabilidades de ocurrencia e impacto de las posibles amenazas, así como los efectos que una interrupción puede tener en la actividad del organismo?
¿Se ha elaborado y documentado una estrategia de continuidad de las actividades del organismo consecuente con los objetivos y prioridades acordadas?
¿Se han aprobado planes de continuidad de las actividades del organismo de conformidad con la estrategia de continuidad acordada?
¿Se han coordinado pruebas y actualizaciones periódicas de los planes y procesos implementados?
¿Se ha considerado la contratación de seguros que podrían formar parte del proceso de continuidad de las actividades del organismo?
¿Se han identificado los eventos (amenazas) que puedan ocasionar interrupciones en los procesos de las actividades como por ejemplo, fallas en el equipamiento, comisión de ilícitos, interrupción del suministro de energía eléctrica, inundación e incendio?
¿Se han evaluado los riesgos para determinar el impacto de dichas interrupciones, tanto en términos de magnitud de daño como del período de recuperación?
¿Se identificaron los recursos críticos, los impactos producidos por una interrupción, los tiempos de interrupción aceptables o permitidos, y se especificaron las prioridades de recuperación?
¿Se han identificado los controles preventivos (sistemas de supresión de fuego, detectores de humo y fuego, contenedores resistentes al calor y a prueba de agua para los medios de <i>backup</i> , los registros no electrónicos vitales, etc)?
¿Han participado los propietarios de los procesos y recursos de información y el Responsable de Seguridad Informática en el proceso de identificación y evaluación de riesgos?
¿Se consideraron todos los procesos de las actividades del organismo sin limitarse a las instalaciones de procesamiento de la información?
Como resultado de la evaluación de riesgos ¿se ha desarrollado un plan estratégico para determinar el enfoque global con el que se abordará la continuidad de las actividades del organismo?
¿El plan estratégico ha sido aprobado por el Comité de Seguridad de la Información?



Comité de Seguridad de la Información
Coordinación General

Dicho Comité ¿ha elevado el Plan Estratégico a la máxima autoridad de la organización para su aprobación?	
Los planes de contingencia necesarios para garantizar la continuidad de las actividades del organismo ¿han sido elaborados por los propietarios de procesos y recursos de información con la asistencia del Responsable de Seguridad Informática?	
¿Han sido dichos planes aprobados por el Comité de Seguridad de la Información?	
Durante el proceso de planificación ¿se han identificado acuerdos respecto de todas las responsabilidades y procedimientos de emergencia?	
¿Se ha realizado el análisis de los posibles escenarios de contingencia y definición de acciones correctivas a implementar en cada caso?	
¿Se implementaron procedimientos de emergencia para permitir la recuperación y restablecimiento en los plazos requeridos, prestando especial atención a la evaluación de las dependencias externas y a los contratos vigentes?	
¿Se documentaron los procedimientos y procesos de emergencia acordados?	
¿Se llevó a cabo la capacitación adecuada del personal en materia de procedimientos procesos de emergencia incluyendo el manejo de crisis?	
¿Se desarrolló el proceso de capacitación del personal involucrado en los procedimientos de reanudación y recuperación?	
¿Se focalizó la capacitación sobre el objetivo del plan?	
¿Se trataron mecanismos de coordinación y comunicación entre equipos (personal involucrado)?	
¿Se incluyeron procedimientos de divulgación en el plan de contingencia?	
¿Se contemplaron requisitos en materia de seguridad?	
¿Se adecuaron procesos específicos para el personal involucrado? ¿Cuenta el personal involucrado con documentación específica que indique cuál es su participación en el proceso de contingencia?	
¿Se consideraron responsabilidades individuales?	
El proceso de planificación ¿se ha concentrado especialmente en los objetivos de las actividades que desarrolla el organismo?	
¿Existen copias de los planes de contingencia almacenados en sitios alternativos?	
¿Se mantiene un único marco para los planes de continuidad, garantizando de esta manera que los mismos sean uniformes e identificando prioridades de prueba mantenimiento?	
¿Están claramente especificados en cada plan de continuidad las condiciones para su puesta en marcha?	
¿Se designó a los responsables de ejecutar cada componente del mismo?	



Comité de Seguridad de la Información
Coordinación General

En caso de requerirse modificaciones, ¿están las mismas aprobadas por el Comité de Seguridad de la Información?
¿Se designó para cada plan de continuidad un administrador y un encargado de coordinar las tareas definidas en el mismo?
¿Se realiza la previsión de las condiciones de implementación de los planes que describan los procesos a seguir antes de poner en marcha los mismos?
¿Se encuentran definidos los procedimientos de emergencia que describan las acciones a emprender una vez ocurrido un incidente que ponga en peligro las operaciones del organismo y/o la vida humana?
¿Existen procedimientos de emergencia que describan las acciones a emprender para el traslado de actividades esenciales del organismo o de servicios de soporte a ubicaciones transitorias alternativas?
¿Se redactaron los procedimientos de recuperación que describan las acciones a emprender para restablecer las operaciones normales del organismo?
¿Se definió un cronograma de mantenimiento que especifique cómo y cuándo se probará el plan, y el proceso para el mantenimiento del mismo?
¿Se realizaron actividades de concientización y capacitación diseñadas para propiciar la comprensión de los procesos de continuidad del negocio y garantizar que los procesos sigan siendo eficaces?
¿Se encuentran documentadas las responsabilidades de las personas, describiendo la responsabilidad de la ejecución de cada uno de los componentes del plan y las vías de contacto posibles, mencionando alternativas cuando corresponda?
¿Se designó al responsable de declarar el estado de contingencia y se definieron detalladamente sus funciones?
¿Se tiene conocimiento y disponibilidad en el organismo de los planes de contingencia de los proveedores de los servicios utilizados, así como la obligación contractual de los mismos de disponer de dichos planes?
¿Existe un cronograma de pruebas periódicas de cada uno de los planes de contingencia?
¿Se indica en el cronograma de pruebas a los responsables de llevar a cabo cada una de las pruebas y de elevar el resultado obtenido al Comité de Seguridad Informática?
¿Se utilizan técnicas para garantizar que los planes de contingencia funcionarán ante un hecho real?
¿Se efectuaron pruebas de discusión de diferentes escenarios evaluando diferentes alternativas de recuperación del negocio?
¿Se realizaron simulaciones (especialmente para entrenar al personal en el desempeño de sus roles de gestión luego de incidentes o crisis)?
¿Se efectuaron pruebas de recuperación técnica para garantizar que los sistemas de información puedan ser restablecidos con eficacia?



Universidad Tecnológica Nacional
Rectorado

Comité de Seguridad de la Información
Coordinación General

¿Se realizaron ensayos completos para verificar que en el organismo, el personal, el equipamiento, las instalaciones y los procesos pueden afrontar las interrupciones?
¿Se han tomado en cuenta mecanismos para las operaciones críticas del organismo?
¿Se efectúan pruebas de recuperación en un sitio alternativo (ejecutando los procesos de las actividades del organismo en paralelo, con operaciones de recuperación fuera del sitio principal)?
¿Se realizan pruebas de instalaciones y servicios de proveedores para garantizar, por medio de convenios por escrito, que los productos y servicios de proveedores externos cumplan con el compromiso contraído?
¿Se realizan las pruebas a partir de una evaluación de los riesgos?
Las pruebas incluyen el uso de instalaciones alternativas?
¿Se revisan y actualizan periódicamente los planes de continuidad de las actividades del organismo para garantizar su eficacia permanente?
¿Cuál fue el resultado de la última prueba? ¿Se registraron progresos respecto de la anterior?
¿Existe un programa de administración de cambios del organismo que incluya procedimientos para garantizar que se aborden adecuadamente los tópicos de continuidad de las actividades?
Los planes de continuidad ¿reflejan todos los cambios en las disposiciones relativas a las actividades del organismo?
¿Se definieron procedimientos que mantengan oportuna y permanentemente actualizados los datos de los planes respecto de cambios o modificaciones en la legislación, estrategia del organismo, tecnologías, requisitos operacionales, requisitos de seguridad?
¿Se definieron las modificaciones a los planes de contingencia que deben ser aprobadas por el Comité de Seguridad de la Información? ¿Se las implementó?
¿Se comunicó fehacientemente a todo el personal los planes de contingencia y las modificaciones realizadas a los mismos?



Comité de Seguridad de la Información
Coordinación General

12.1. CUMPLIMIENTO
¿Definió el Responsable de la Seguridad Informática normas y procedimientos que garanticen el cumplimiento de restricciones legales en el uso de material protegido por normas de propiedad intelectual?
¿Incluyen estas normas de procedimiento controles específicos y responsabilidades individuales que garanticen el cumplimiento de los recursos de tecnología informática?
¿Se realizan revisiones periódicas de todas las áreas del organismo con el objeto de garantizar el cumplimiento de las políticas, normas y procedimientos de seguridad?
¿Se verifica que los sistemas de información cumplan con las políticas, normas, y procedimientos de seguridad establecidas?
¿Se solicita, en caso de ser necesario, la participación de especialistas externos?
El funcionario a cargo del Área Legal con la asistencia del Responsable de la Seguridad Informática ¿definieron y documentaron todos los requisitos legales, normativos y contractuales que debe cumplir cada uno de los sistemas de información?
El funcionario a cargo del Área Legal con la asistencia del Responsable de la Seguridad Informática ¿redactaron un Acuerdo de Confidencialidad para ser suscripto por todos los integrantes de la organización?
¿Es conocida la Política de Seguridad de los Sistemas de Información para organismos de la Administración Pública Nacional por los distintos niveles de la organización (empleados, mandos medios y superiores)? ¿Ha sido difundida fehacientemente?
¿El Comité de Seguridad provee los medios necesarios ante cualquier irregularidad relacionada con la seguridad de la información y se ocupa de la individualización de los posibles responsables?
¿Se garantiza la correcta implementación y cumplimiento de las normas y procedimientos de seguridad establecidos en la siguiente política?
¿Existe una figura sobre la cual recae la responsabilidad de hacer cumplir las normas y procedimientos de seguridad?



Universidad Tecnológica Nacional
Rectorado

Comité de Seguridad de la Información
Coordinación General

12.2. POLÍTICAS	
¿Están definidos y documentados claramente todos los requisitos legales, normativos y contractuales presentes para cada sistema de información?	
¿Existen definiciones documentadas para los controles específicos y las responsabilidades individuales para cumplir con dichos requisitos?	
¿Se han implementado procedimientos adecuados para garantizar el cumplimiento de las restricciones legales al uso del material protegido por las normas de propiedad intelectual?	
¿Utilizan los empleados únicamente material autorizado por el organismo?	
¿Se respetan las normas que fijan los derechos de propiedad intelectual de los sistemas de información, procedimientos, documentación y plataformas, en los términos de la Ley 11.723, Ley de Marcas N° 22.362 y Ley de Patentes de Invención y Modelos Ley 24.481?	
¿Existen políticas que contemplen el cumplimiento del derecho de propiedad intelectual sobre los productos de información y del software?	
¿Contienen las normas de procedimiento el listado del material a utilizar por los empleados?	
¿Se controla que dicho material sea el único utilizado por el personal?	



Comité de Seguridad de la Información
Coordinación General

12.3. DERECHO DE PROPIEDAD INTELECTUAL DEL SOFTWARE
¿Se realizan acciones para lograr la concientización del personal respecto de las políticas de adquisición y derecho de propiedad intelectual sobre la adquisición del software?
¿Se divulgan debidamente estas políticas sobre adquisición de software?
¿Se definieron las sanciones disciplinarias para los casos en que se infrinja la Ley 11.723 sobre Propiedad Intelectual?
¿Existe un adecuado registro o inventario de los productos adquiridos en el marco de la Ley 11.723 de Propiedad Intelectual?
¿Se conservan adecuadamente los certificados de licencias, discos maestros, manuales que se adquieren?
¿Se controla el número máximo de usuarios que permite cada licencia?
¿Se instalan sólo productos con licencia y software autorizados?
¿Se realizan comprobaciones sobre éstos productos?
El Responsable de la Seguridad Informática ¿realiza revisiones periódicas de todas las áreas del organismo con el objeto de determinar si se garantiza el cumplimiento de la Ley de Marcas (Nº 22.362) y Ley de Patentes (Nº 24.481)?
¿Se cuenta con un procedimiento para el mantenimiento de las condiciones adecuadas de uso con respecto a las licencias que incluya además la eliminación o transferencia de software a terceros?
¿Se cumple con los términos y condiciones establecidos para obtener información o software de las redes públicas?



Comité de Seguridad de la Información
Coordinación General

12.4. PROTECCION DE LOS REGISTROS DEL ORGANISMO
¿Se determinaron los procedimientos para la retención, almacenamiento, manipulación y eliminación de registros?
¿Se diseñaron los procedimientos para la retención, almacenamiento, manipulación y eliminación de la información?
¿Se efectúan controles para proteger la información y los registros esenciales contra pérdida, destrucción o falsificación?
¿Se clasifican los registros críticos de distintos tipos como por ejemplo contables, de bases de datos, logs de transacciones, logs de auditoria, procedimientos operativos, etc?
¿Se cuenta con un inventario de programas fuentes de información clave?
¿Se ha considerado la degradación de los medios utilizados para el almacenamiento de los registros?
¿Se definieron para cada una de estas clasificaciones los períodos de retención y el tipo de medios de almacenamiento ante futuros cambios tecnológicos?
¿Incluye el Acuerdo de Confidencialidad los requerimientos necesarios para la protección de los registros del organismo?
¿Compromete el acuerdo a los empleados a usar la información solamente para el uso específico para el que ha sido destinada y a no comunicar, difundir o de alguna otra forma hacer pública la información?
¿Cumple con el decreto 1172/03, que regula el acceso a la información pública por parte de los ciudadanos?
El Acuerdo de Confidencialidad, ¿ha sido suscrito por todos los miembros de la organización?
¿Se resguarda la copia firmada en un archivo seguro? Indique cuál
Se utilizan firmas digitales?
Las condiciones de uso de las firmas digitales ¿cumplen con lo dispuesto por la normativa vigente en materia de firma digital?
¿Las claves criptográficas asociadas con archivos cifrados o firmas digitales se mantienen en forma segura?
¿Están disponibles para su uso por parte de personas autorizadas?
¿Se cumple, respecto de la exportación de determinados bienes, con toda la normativa vigente en materia de control de Exportaciones Sensitivas y de Material Bélico?
En los casos en que deba exportarse información cifrada o controles criptográficos ¿se solicita asesoramiento a las autoridades competentes en la materia?
¿Existen normas de procedimiento sobre el resguardo de documentación para los casos en que deba respaldarse una acción contra una persona u organización?



Universidad Tecnológica Nacional
Rectorado

Comité de Seguridad de la Información
Coordinación General

¿Se almacena la documentación en papel (en originales) en forma segura?
¿Durante la investigación se garantiza que no se alteren los originales?
En caso de ocurrir un evento que requiera investigación ¿se cuenta con un registro adecuado de quién, dónde y cuándo halló la evidencia?
En caso de que ocurra un evento que requiera investigación ¿se resguarda, siempre que sea posible, la información en medios informáticos removibles y discos rígidos?
¿Se mantiene un registro de las acciones realizadas durante el proceso de copia?
En este proceso de copia ¿participa un tercero independiente a los fines de garantizar que no se modifiquen los elementos de prueba?
¿Se almacena en forma segura una copia de los medios y del registro?
En el caso de detectarse una irregularidad relacionada con la seguridad de la información ¿se controla el cumplimiento con toda la normativa vigente en materia de investigaciones y procedimientos administrativos?
El Comité de Seguridad de la Información ¿provee los medios necesarios para la resolución de cualquier irregularidad relacionada con la seguridad de la información, ocurrida en el ámbito del organismo y la individualización de los responsables?
Los integrantes de la organización ¿conocen el alcance preciso del uso adecuado de los recursos informáticos en cumplimiento con la normativa en vigencia en materia laboral, de ética en el ejercicio de la Función Pública y de confidencialidad de la información?
En el caso de detectarse una irregularidad relacionada con la seguridad de la información ¿Se efectúa la correspondiente denuncia por violación al Código Penal?



Comité de Seguridad de la Información
Coordinación General

12.5. REVISIONES DE POLITICAS DE SEGURIDAD Y COMPATIBILIDAD TÉCNICA
Los responsables de las unidades organizativas ¿Garantizan la correcta implementación y cumplimiento de las normas y procedimientos de seguridad dentro de su área de responsabilidad?
¿Participa cada responsable de las Unidades Organizativas en las revisiones?
El Responsable de la Seguridad Informática ¿realiza revisiones periódicas acerca de la correcta implementación y cumplimiento de las normas y procedimientos de seguridad considerando los sistemas de información, los servicios prestados por terceros, los propietarios de información, los proveedores de sistemas, los usuarios y los gerentes?
El Responsable de Seguridad Informática ¿Verifica la compatibilidad técnica entre los recursos de tecnología Informática y las políticas, normas y procedimientos de Seguridad Informática?
El Responsable de Seguridad Informática ¿evalúa la correcta implementación y cumplimiento de las normas y procedimientos de seguridad de los sistemas en producción a fin de garantizar la aplicación de los controles en hardware y software?
En caso de ser necesario ¿se requiere de la asistencia técnica especializada?
¿Se confeccionan informes técnicos con el resultado de esta evaluación?
¿Son estos informes analizados por especialistas o por un paquete de software que emita reportes a ser posteriormente analizados por los especialistas técnicos? Especificar qué metodología se utiliza.
¿Para la verificación de la compatibilidad técnica con normas, políticas y procedimientos se realizan pruebas de penetración en los sistemas de información con o sin asistencia de especialistas?
En los casos en que durante estas pruebas se comprueben vulnerabilidades en los sistemas ¿se toman los recaudos necesarios para subsanarlos?
Las verificaciones de compatibilidad técnica con políticas, normas o procedimientos ¿son llevadas a cabo por personas competentes y autorizadas formalmente? ¿Se las supervisa?

12.6. SANCIONES PREVISTAS POR INCUMPLIMIENTO
¿Se encuentran previstas sanciones para todo aquel integrante de la organización que viole lo dispuesto en las Políticas de Seguridad conforme lo dispuesto por las normas estatutarias, escalafonarias y convencionales que rigen al personal de la Administración Pública?



Comité de Seguridad de la Información
Coordinación General

12.7. CONSIDERACIONES DE AUDITORIAS DE SISTEMAS

Durante la etapa de planificación de requerimientos y tareas de la Auditoria de Sistemas en producción ¿Se acordó con el Área de Sistemas los requerimientos necesarios para realizarla?

¿Se define claramente el alcance de las verificaciones por parte del responsable de auditoria?

¿Las verificaciones se realizan con acceso “sólo lectura” del software y datos de producción?

Caso contrario ¿se efectúan acciones tendientes a neutralizar las modificaciones realizadas durante la auditoria?

¿Se identificaron claramente los recursos de la TI puestos a disposición para llevar a cabo las verificaciones de auditoria?

¿Se aplica sobre sistemas de información?

¿Bases de datos?

¿Hardware?

¿Software de auditoria?

¿Medios magnéticos?

¿Personal de Auditoria?

¿Interlocutores de las áreas informáticas?

¿Interlocutores de las áreas Usuarías?

¿Conexiones de Red?

¿Se identificaron y acordaron los requerimientos de procesamiento especial o adicional?

Durante las verificaciones ¿se monitorean y registran todos los accesos a fin de generar una pista de referencia?

¿El seguimiento y resguardo mencionado contiene como mínimo fecha y hora de acceso, puesto de trabajo, usuario, tipo de acceso, identificación de los datos accedidos, estado previo y posterior, programa y/o función realizada?

¿Los procedimientos de auditoria cuentan con papeles de trabajo que los documenten?

¿Los requerimientos efectuados al área de informática cuentan con respaldo necesario?

¿Se encuentran definidas y documentadas las responsabilidades de cada uno de los auditores que intervienen en el procedimiento?

¿El acceso a los archivos de datos y el software, se encuentran protegidos con el objeto de evitar el mal uso o compromiso de los mismos?

Las herramientas utilizadas ¿se encuentran separadas de los sistemas de producción y de desarrollo?

¿Se les otorga el nivel de protección requerido?



Universidad Tecnológica Nacional
Rectorado

Comité de Seguridad de la Información
Coordinación General